



TEMA 3

DEFENDIENDO ENDPOINTS



Cómo defender nuestros sistemas y su software instalado



"S-82 NARCISO MONTURIOL" PROJECT v5.0

Por favor, informa de problemas con los materiales a redondojose@uniovi.es



Departamento de Informática
Universidad de Oviedo



Universidad de Oviedo

Logo: @creative_vanesa (Instagram)

OBJETIVOS GENERALES DEL TEMA

- **Entender cómo proteger un sistema operativo**
 - Y qué áreas requieren acciones específicas
- **Conocer software especializado de protección/monitorización**
 - Para ciertas áreas de los sistemas operativos
- **Aprender cómo se mejora la seguridad del software en general**
 - Centrándose en **automatización** y aplicación de **controles técnicos de seguridad** adecuados
 - Más la **evaluación del nivel de seguridad** actual
- **Aprender cómo esto puede facilitar la implementación de políticas de seguridad y SGSI**
- **Y, relacionado con otras asignaturas...**
 - Usar conceptos de **SO** conocidos para mejorar la seguridad
 - Complementar los contenidos de **ASR** desde el punto de vista de la seguridad





ÍNDICE



Introducción: La “cadena de seguridad”



Gestionando los permisos y acciones de los usuarios



Logs, auditoria y monitorización de sistemas



Automatización del hardening de seguridad



Esquema Nacional de Seguridad (ENS) Español



Security Content Automation Protocol (SCAP)



Fuentes de listas de controles de seguridad SCAP validados



El camino a las políticas de seguridad



Controles de seguridad no técnicos



Frameworks de seguridad y SGSI

[< Ir al índice](#)

[Permisos de usuario >](#)

[Monitorización >](#)



LA "CADENA DE SEGURIDAD"

La seguridad como un esfuerzo combinado



Departamento de Informática
Universidad de Oviedo



Universidad de Oviedo

¿QUÉ VAS A ENCONTRARTE EN ESTE BLOQUE?

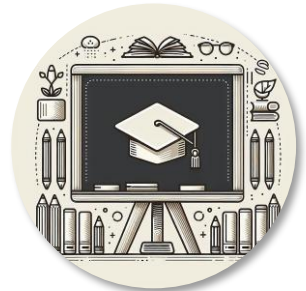
● En este bloque aprenderás

- Los elementos involucrados en una típica "**cadena de seguridad**"
- Que los usuarios son a menudo **el eslabón más débil** de la cadena
- Cuáles son los orígenes de **defectos de seguridad del software** más comunes
- Cómo gestionar los **permisos de los usuarios** de forma segura
- El omnipresente "**principio de minimización**"
- Que usar una fuente adecuada de controles técnicos de seguridad es la clave para lograr una seguridad de software adecuada
- Que **monitorizar lo que pasa en los sistemas** es obligatorio para lograr una seguridad adecuada



LA SEGURIDAD COMO "CADENA"

- El nivel de seguridad de una organización es una "cadena" compuesta por
 - El **sistema operativo** usado en los endpoints de la infraestructura
 - Las **aplicaciones de terceros instaladas** (navegadores, Office...)
 - El software que diseñamos e implementamos (**Tema 5**)
 - **La formación y la concienciación del usuario**
 - El contexto del **lugar donde están físicamente** los endpoints (**Seminario 2**)
- Todos los elementos de la cadena pueden tener defectos de seguridad
 - El nivel de seguridad global es el que tiene el eslabón más débil
 - Y ese eslabón **suelen ser los usuarios** 😞



ORÍGENES TÍPICOS DE DEFECTOS DE SEGURIDAD

- La mayoría de los defectos son producidos por...
 - **Proceso de arranque inseguro** (Ej.: secuestro con un USB bootable)
 - *¿Qué se puede hacer si te secuestran el proceso de arranque?*
 - Instalaciones con una **configuración por defecto no segura**
 - Puedes usar herramientas para mejorarlas, como **WebMin**
 - Pero es mejor usar **controles técnicos de seguridad adecuados**
 - **Funcionalidades inseguras**
 - Ej.: Conectar dispositivos USB maliciosos/infectados a endpoints
 - *¿Cuál es el problema general con estos dispositivos?*
 - Usuarios y/o código **con privilegios excesivos**
 - *¿Qué problema tiene esto?*
 - **Errores del usuario** (el peor problema)
 - Ej.: Abrir archivos adjuntos de emails maliciosos, problemas para manejar información privada, ser víctima de phishing...
 - **Errores de administración del sistema / software** (siguiente diapositiva)



ERRORES DE ADMINISTRACIÓN DEL SISTEMA / SOFTWARE



- **El malware se aprovecha de los defectos (errores de seguridad o vulnerabilidades) en el software**
 - Sacando partido de errores u olvidos para **explotarlos**
- **Esto puede pasar por...**
 - Aplicaciones **obsoletas**
 - Aplicaciones / complementos / módulos /... (software) con **vulnerabilidades conocidas**
 - *¿La instalación de una versión de una aplicación desinstala automáticamente la anterior?*
- **Contramedidas**
 - Supervisar los **avisos de seguridad** de proveedores y las **bases de datos de CVE (Tema 1)**
 - De forma manual o automática (Ej.: Herramientas SCA, **Tema 6**)
 - Crear un "**inventario**" adecuado de todo: software, sistemas operativos, nivel de parches...
 - **Aplicar el "principio de minimización" en todo**: Usuarios, software, permisos...
 - Usar **controles técnicos de seguridad adecuados** para mejorar su configuración

-

EL PRINCIPIO DE MINIMIZACIÓN ES CLAVE

- “**Instala solo lo que *REALMENTE* vas a usar**”
 - Cuantos **menos usuarios activos** tengas, mejor. *¿Por qué?*
 - Cuantos **menos programas/servicios** hayas instalado, mejor. *¿Por qué?*
 - Cuantos **menos procesos** se ejecuten en un momento dado, mejor. *¿Por qué?*
 - Cuantas **menos formas de acceder a un sistema**, mejor. *¿Por qué?*
 - Usando los medios más seguros posibles (MFA, **Tema 4**)
- Así que, cuanto menos <lo que sea>... mejor 😊





Gestión de privilegios y acciones de usuario

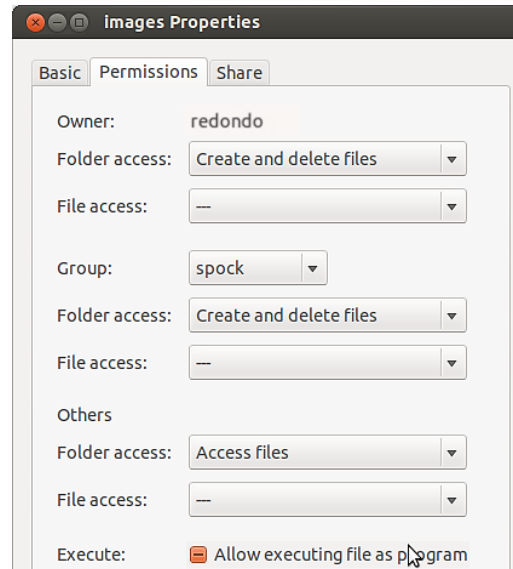
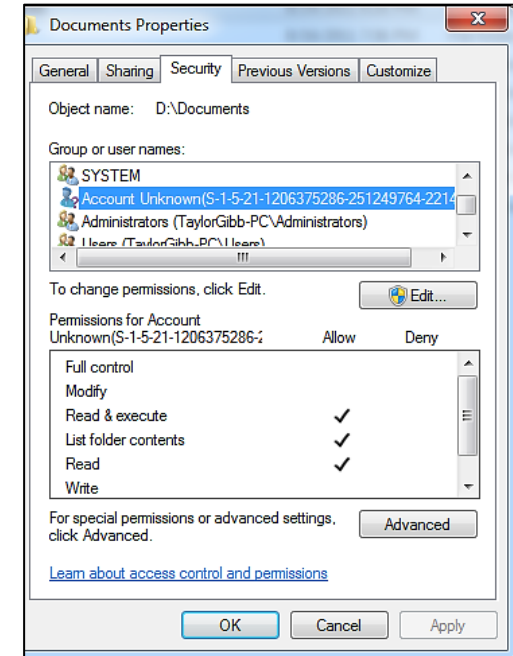
Da a los usuarios solo el acceso estrictamente necesario; Tipos de control de acceso



DAC (DISCRETIONARY ACCESS CONTROL)



- Los "típicos" **permisos** (SO, ASR)
- Restringir el acceso a identidades o grupos de usuarios ("Roles")
 - ¿Se puede cambiar el propietario de un recurso? ¿Por qué puede ser eso un problema?
- ¿Cómo asigno los permisos adecuados? ¡Ya lo hemos dicho! 😊
 - Principio de minimización
 - Seguir **controles de seguridad técnicos adecuados** relacionados con los permisos, de una fuente fiable
 - ¿No te parece que hay un patrón? 😊



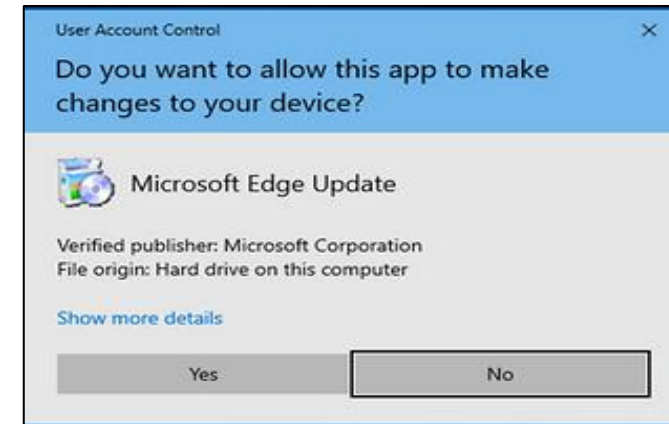
MAC (MANDATORY ACCESS CONTROL)

- Una entidad (Ej.: el SO) restringe forzosamente la capacidad a un sujeto para acceder a un recurso o hacer una operación

- Funciona **antes** de evaluar los permisos del archivo (DAC)
 - MAC primero y, si está bien, DAC
- Los controles de seguridad técnicos adecuados deberían habilitar MAC

- Ejemplos

- Funciones del kernel de Linux: SELinux (RedHat); AppArmor (Debian)
- Windows Mandatory Integrity Control (MIC)
 - Combina **4 niveles de integridad** (IL) (low, medium, high y system)
 - Los usuarios estándar reciben **medium**, los usuarios privilegiados reciben **high**
 - Los procesos iniciados por el usuario reciben el IL "low" si el IL de su archivo ejecutable es "low"
 - Los servicios del sistema reciben el IL "system" (el máximo)
 - Con una **política obligatoria** para evaluar el acceso
 - Un proceso **no puede interactuar con otro que tenga un IL más alto**



Windows MIC. Lo bueno es que viene activo por defecto. Fuente: :

<https://helpdesk.athens.edu/hc/en-us/articles/4404584871575-Microsoft-Edge>

- *¿Qué pasa si atacantes obtienen acceso interactivo a una cuenta de usuario activa?*
- Se deben implementar contramedidas...
 - ... ¡con **controles técnicos de seguridad adecuados** de fuentes fiables! (*¿A que no te lo esperabas? ☺*)
- Estos controles normalmente incluyen...
 - Tener un solo administrador, que no pueda **iniciar sesión de forma interactiva**
 - **Todos los usuarios son estándar**, menos si deben hacer una operación privilegiada (Ej.: Instalar software)
 - Dar a esos usuarios un mecanismo de "promoción temporal" (como **sudo** o **su**). *¿Por qué? ¿A todos ellos?*
 - **Métodos de acceso seguro**, habilitando también MFA (**Tema 4**)
 - Ej. MFA en SSH: <https://medium.com/mi-rincon/doble-factor-de-autenticacion-2fa-c2c8d728b978>
 - Hacerse **passwordless** (*¿Cómo?*), **eliminar los usuarios** (*¿Cómo?*) o **usar contraseñas seguras**
 - Evitar arrancar en **modo recuperación / single user**
 - *¿Qué nivel de acceso crees que tiene el usuario de "recuperación" en este modo?*
 - *¿Te imaginas una razón legítima para usar esta función?*

¿CREEES QUE LO HAS ENTENDIDO TODO? ¡EVALÚATE A TI MISMO!



● Puedes hacer lo siguiente

- *Comprender las principales fuentes de problemas de seguridad típicos en el software*
- *Entender la diferencia entre DAC y MAC*
- *Entender que cuantos menos usuarios puedan iniciar sesión en el sistema, mayor será la seguridad*
 - *Incluyendo minimizar el número de `sudoers` en Linux*
- *Comprender que todo servicio de acceso remoto a un sistema debe tener un MFA*
- *Entender por qué es tan importante operar como una cuenta con privilegios elevados durante el menor tiempo posible*
 - *Incluida la prohibición del acceso interactivo con estas identidades de usuario*
- *Y que todas las medidas de seguridad que implementes deben seguir los controles de seguridad adecuados*



Logs, auditoría y monitorización del sistema

Registrar y detectar lo sucedido



IMPLEMENTACIÓN DE MONITORIZACIÓN/AUDITORÍA ADECUADA

- Registrar (auditar) **actividades** del sistema/usuario, **eventos** de seguridad y uso de recursos es **VITAL**

- Las políticas de auditoría también son parte de los controles técnicos de seguridad
- Cada vez que haces algo en un sistema local/remoto... ¡Tus acciones se registran! 🤖

- Implementar una auditoría adecuada significa

- **Administración general de logs del sistema:** el daemon/servicio de auditoría no debe deshabilitarse y debe tener una configuración inmutable. *¿Por qué?*
 - *¿Qué información debemos almacenar en los logs? ¿Dónde podemos encontrar la configuración de log correcta?*
- **Administración del tamaño del log:** Los archivos de registro deben tener un límite de tamaño. *¿Por qué?*
 - Y debe conservarse durante un período requerido
 - *¿Qué debemos hacer si el log crece demasiado o agota el espacio? ¿Dónde podemos encontrar la configuración de log correcta?*

```
redondo@redondo-VirtualBox: /
drwxr-xr-x 14 root root 4096 ago 19 2021 var
redondo@redondo-VirtualBox:/$ ls -la /var/log
total 6156
drwxrwxr-x 15 root      syslog      4096 sep 14 09:55 .
drwxr-xr-x 14 root      root         4096 ago 19 2021 ..
-rw-r--r-- 1 root      root          359 sep  3 11:03 alternatives.log
-rw-r--r-- 1 root      root     31421 ago 12 12:42 alternatives.log.1
-rw-r--r-- 1 root      root      441 nov 17 2021 alternatives.log.10.gz
-rw-r--r-- 1 root      root      126 oct  7 2021 alternatives.log.11.gz
-rw-r--r-- 1 root      root     4056 sep 29 2021 alternatives.log.12.gz
-rw-r--r-- 1 root      root      144 jul 28 20:54 alternatives.log.2.gz
-rw-r--r-- 1 root      root      127 jun 13 17:45 alternatives.log.3.gz
-rw-r--r-- 1 root      root      168 may 23 21:01 alternatives.log.4.gz
-rw-r--r-- 1 root      root      442 abr 20 19:01 alternatives.log.5.gz
-rw-r--r-- 1 root      root      273 mar 24 23:11 alternatives.log.6.gz
-rw-r--r-- 1 root      root      449 feb 15 2022 alternatives.log.7.gz
-rw-r--r-- 1 root      root      513 ene 21 2022 alternatives.log.8.gz
-rw-r--r-- 1 root      root      143 dic 21 2021 alternatives.log.9.gz
-rw-r----- 1 root      adm           0 sep 10 10:00 apport.log
-rw-r----- 1 root      adm      113 sep  9 13:22 apport.log.1
-rw-r----- 1 root      adm      119 sep  8 11:44 apport.log.2.gz
-rw-r----- 1 root      adm      120 sep  7 16:38 apport.log.3.gz
-rw-r----- 1 root      adm      120 sep  6 09:15 apport.log.4.gz
-rw-r----- 1 root      adm      119 sep  5 19:38 apport.log.5.gz
```

Logs rotados (renombrados y comprimidos si es necesario en el futuro)

IMPLEMENTACIÓN DE MONITORIZACIÓN/AUDITORÍA ADECUADA



- Las ubicaciones del log por SO se explican en **ASR**
 - IFA enseña cómo analizar e interpretar el contenido del log
 - Se usan técnicas de ML/IA (**SI**) para analizar el contenido del log e identificar amenazas
- Los archivos de log de un sistema suelen contener
 - Fecha, hora y usuario que realizó una acción
 - Detalles sobre cada acción importante
- Hay muchos logs, pertenecientes a los principales servicios del sistema
 - <https://thehackerway.com/2021/06/21/15-ficheros-de-log-interesantes-en-sistemas-linux/>
- Pero, normalmente, los logs capturan mucha información
 - Detectar posibles amenazas procesándolas manualmente es muy difícil
 - *¿Cómo podemos aprovechar REALMENTE la información de registro por seguridad?*
 - ¡Usando herramientas automatizadas de monitorización de seguridad que procesan logs! 😊

IMPLEMENTACIÓN DE MONITORIZACIÓN/AUDITORÍA ADECUADA

- La **detección automatizada de anomalías / amenazas** necesita software especializado
 - ¡Seguridad y automatización van de la mano! 😊
- Ej.: **Host-based Intrusion Detection Systems (HIDS)**
 - Analizan logs para **detectar amenazas** en un host determinado
 - Ej: OSSEC (ver imagen)
 - <https://computingforgeeks.com/how-to-install-ossec-hids-on-ubuntu-18-04-16-04-debian-9/>
 - Algunos también hacen **monitorización de políticas, verificación de integridad de archivos, alertas en tiempo real, detección de rootkits, respuestas activas** a amenazas detectadas ...



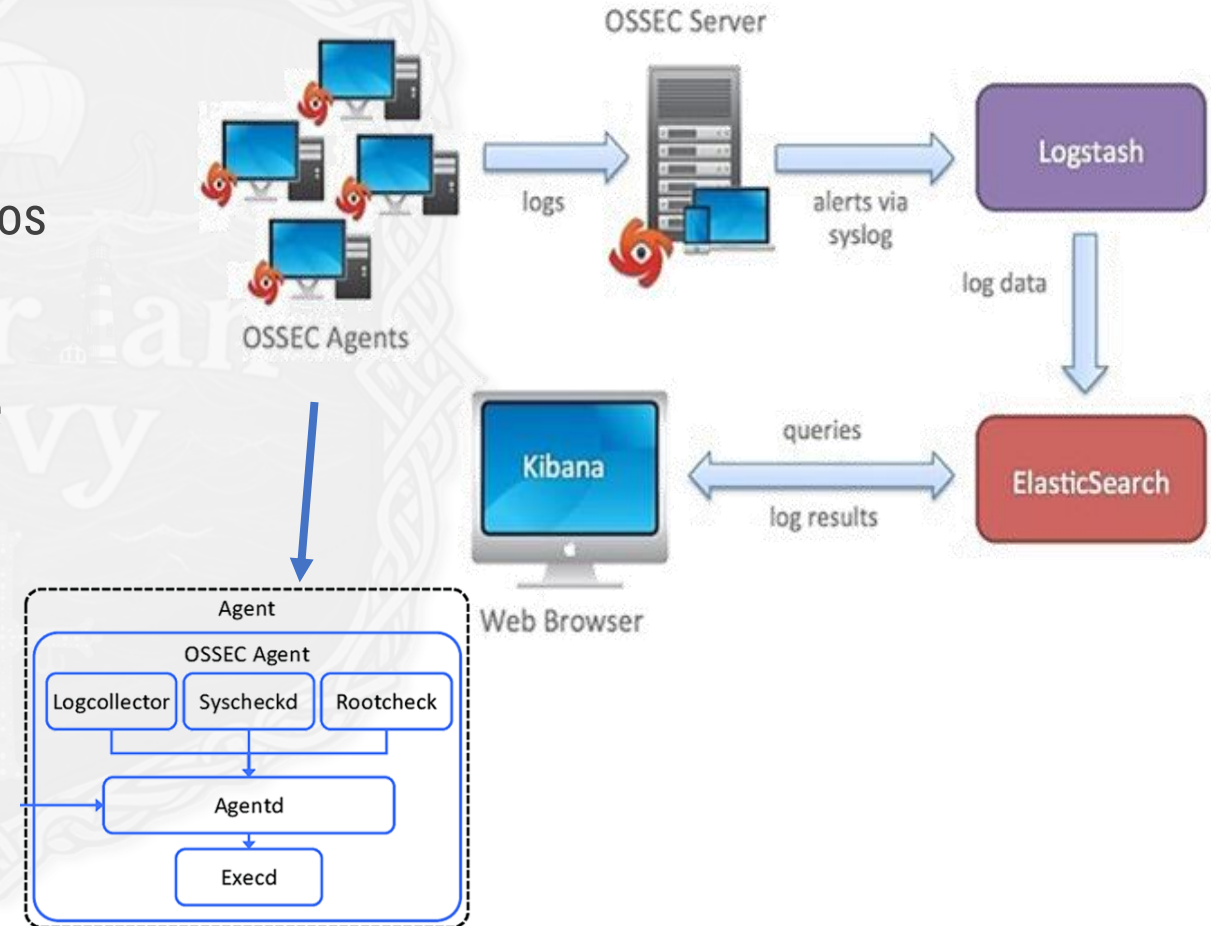
OSSEC integrado y reportando a un OSSIM SIEM (**Tema 5**) (<https://cybersecurity.att.com/products/ossim>), que es como una "central de alarmas", pero en ciberseguridad. OSSEC puede funcionar de forma independiente o formando parte de otros productos, como el Wazuh XDR (visto en laboratorios)

AUTOMATIZACIÓN DE LA AUDITORÍA DE UNA INFRAESTRUCTURA

● ¿Y si tenemos **MUCHOS** sistemas?

- Instalación de **agentes HIDs** en cada endpoint
- Toda esa información se manda a un punto central
 - Los endpoint **NO almacenan registros locales**, los envían a un servidor de registro central
 - *¿Qué ventajas de seguridad tiene esto?*
- Por tanto, se pueden **ver y analizar** globalmente
 - Gracias a herramientas como Kibana y ElasticSearch (**ELK stack**) (**AS**)
 - Y/o software de monitorización de seguridad **XDR/EDR** (con **mucha automatización**)
- Permite una auditoría de infraestructura completamente automatizada
 - Toda la información de log se almacena en un solo lugar
 - Las herramientas de seguridad analizan (y correlacionan) **todo**

Fuente: https://www.researchgate.net/figure/Integration-architecture-of-OSSEC-12_fig1_320649753



Fuente: https://www.researchgate.net/figure/Open-Source-Host-based-Intrusion-Detection-System-OSSEC-components_fig1_335806029

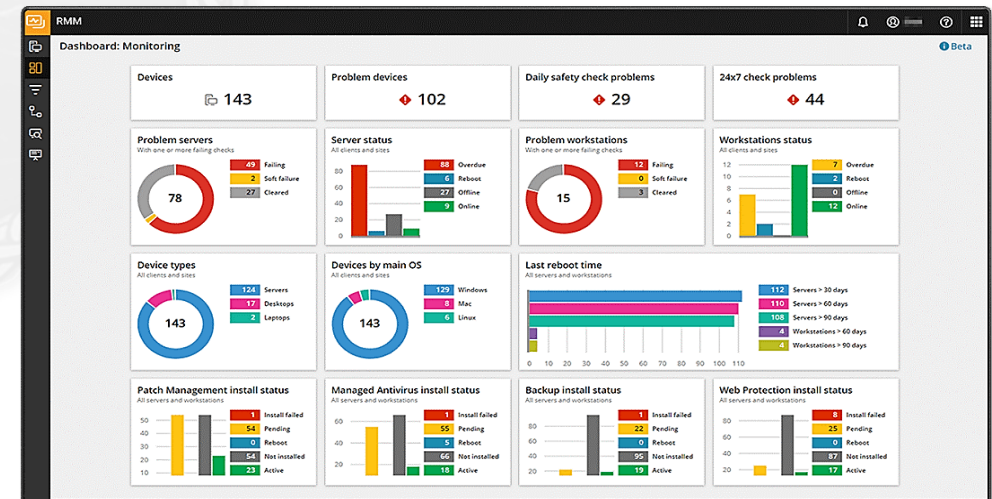
TECNOLOGÍAS ENDPOINT DETECTION AND RESPONSE (EDR/XDR)

- Monitoriza continuamente los endpoints y responde para mitigar las amenazas
 - Ej.: Wazuh (<https://wazuh.com/>)
- Identifica comportamientos sospechosos y **Advanced Persistent Threats (APT)**
 - Recopilan y agregan datos de puntos finales y otras fuentes, y pueden dirigirlos a SIEM (**Tema 5**)
 - Su funcionalidad principal es **alertar a los administradores sobre anomalías**
 - Muchos también integran capacidades de protección y respuesta activa (antimalware, firewall...)
 - Un XDR... ¡¡para gobernarlos a todos!!

Fuente: <https://ar.linkedin.com/company/absega>



Fuente : <https://www.dnsstuff.com/best-edr-solutions>



TECNOLOGÍAS ENDPOINT DETECTION AND RESPONSE (EDR/XDR)

- La monitorización es **CLAVE** para la seguridad actual
 - El antimalware ya no es suficiente
- Pero distinguir entre estos productos es cada vez más difícil
 - Muchos productos que fueron solo antimalware en el pasado ahora evolucionaron a EDR / XDR
 - O muchos EDR/XDR se han mejorado para incluir funcionalidades antimalware
 - Muchos productos que alguna vez fueron EDR evolucionaron a XDR
- Debemos elegir un producto con cuidado

AV vs EDR vs XDR			
Features	AV	EDR	XDR
Scope	Endpoint only	Endpoints	Endpoints, cloud, email, network
Detection	Signature-based	Behavior + analytics	Correlated, AI-driven
Response	Basic (quarantine/delete)	Advanced (isolate, rollback)	Automated across multiple systems
Visibility	Limited to device	Full endpoint view	Unified cross-platform view
Integration	Standalone	SIEM/SOAR compatible	Native multi-tool integration
Data	Minimal logging	Rich endpoint data	Aggregated multi-source data
Alerts	Basic	Detailed, some correlation	Correlated, prioritized alerts
Use Case	Basic user protection	Enterprise endpoint security	SOC-level full environment security
Maturity	Entry-level	Intermediate to advanced	Advanced, proactive defense
Best For	Individuals, small businesses	Security teams	Large orgs & SOCs needing wide coverage

Diferencia entre Antimalware, EDR y XDR. Fuente:

<https://www.linkedin.com/feed/update/urn:li:activity:7376903930926198784/>

¿CREEES QUE LO HAS ENTENDIDO TODO? ¡EVALÚATE A TI MISMO!



?

● Puedes hacer lo siguiente

- *Entender que todo lo relevante que sucede en el sistema y con los usuarios, sea erróneo o no, debe reflejarse en los logs*
- *Tener en cuenta que el volumen de información generado es tal que, sin una herramienta de análisis (como un HIDS), no podríamos ver las amenazas a un sistema*
- *Que, debido a la tremenda importancia de los logs, es muy común almacenarlos externamente en un punto centralizado*
- *Qué es una herramienta de monitorización EDR/XDR y cómo ayuda a identificar problemas potenciales*
- *Comprender cómo la automatización también desempeña un papel clave en la supervisión de sistemas y la detección de amenazas*

[< Ir al índice](#)



AUTOMATIZACIÓN DEL HARDENING DE SEGURIDAD

El hardening no es algo difícil



[ENS >](#)

[SCAP >](#)

[Controles de seg. >](#)



Departamento de Informática
Universidad de Oviedo



Universidad de Oviedo

¿QUÉ VAS A ENCONTRARTE EN ESTE BLOQUE?

- Mejorar la seguridad de cualquier software consiste en **implementar una lista de controles técnicos de seguridad** de una fuente fiable (¡sorpresa! 😊)
 - Sigues una "receta" para mejorar en gran medida la seguridad de cualquier software asociado con esa "receta" (Ubuntu, Windows, Apache 2, Firefox, Chrome...)
 - La "receta" está compuesta por muchos (cientos) de **controles técnicos de seguridad**
 - Debes ejecutar **cientos de scripts**, que pueden cambiar cientos de archivos, para implementarlos
 - ... ¡Pero **no manualmente**! ¡La mayoría de ellos **se pueden automatizar**!
 - Por lo tanto, debes aprender dónde **encontrar estas "recetas"** (y **cómo automatizarlas**)
 - *Entonces, ¿Debes buscar en StackOverflow, Reddit, foros, etc. cómo proteger un software?*
- Por tanto, en este bloque aprenderás
 - Qué es el cumplimiento como código (**Compliance as Code**)
 - Qué es el **Esquema Nacional de Seguridad** español y qué incluye
 - Qué es el **protocolo SCAP** y su importancia para automatizar la seguridad
 - Fuentes adecuadas de **controles técnicos de seguridad** para cualquier software



COMPLIANCE AS CODE (CAC)

- **Cómo expresar los tres aspectos principales de cumplimiento con código ejecutable**
 - **Prevenir** el incumplimiento
 - Para **comprobar automáticamente** que los cambios planificados son compatibles
 - **Detectar** el incumplimiento mediante el **escaneo automatizado**
 - Notificación cuando se identifican problemas
 - **Corregir** el incumplimiento
 - **Hacer cambios** para garantizar el máximo nivel de cumplimiento
- **Los controles técnicos de seguridad adecuados de cualquier software se vuelcan a los programas**
 - Con lenguajes específicos de dominio (DSLs) (**TPP, DLP**) *¿Puedes decir por qué?*
 - ¡Somos ingenieros de software! ¡Los lenguajes de programación son nuestro pan de cada día!
 - Código de programa significa... **¡automatización!** 😊





Esquema Nacional de Seguridad (ENS)

Ley 11/2007, de 22 de junio: Acceso electrónico de los ciudadanos a los servicios públicos. Los controles de seguridad de nuestro país



ESQUEMA NACIONAL DE SEGURIDAD (ESPAÑA)



SSI

Las guías se crean para las administraciones públicas, pero las empresas privadas también pueden usarlas

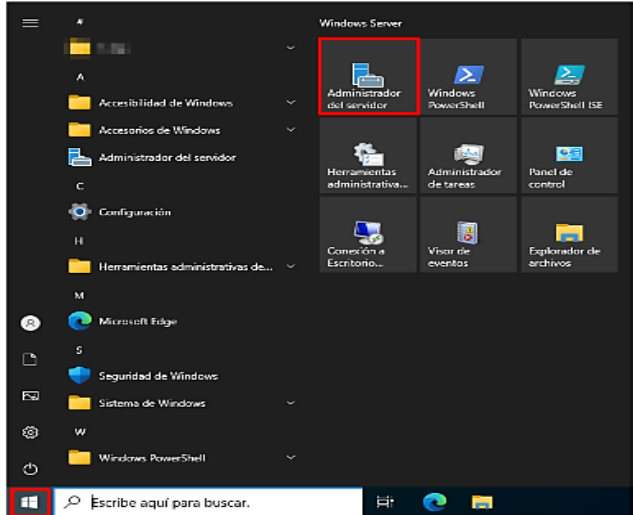
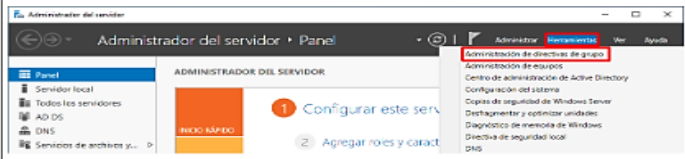
- Principios y requisitos de la política de seguridad española para el uso de medios electrónicos

- Contenidos: <https://www.ccn-cert.cni.es/publico/ens/ens/index.html>
- Marco normativo: <https://ens.ccn.cni.es/es/ens-marco-normativo/ens-marco-normativo-es>

- Y para configurar correctamente el SO / software

- El CCN-STIC publica **guías de seguridad gratuitas** para muchos productos de software con listas de control de seguridad
 - Y **explicaciones detalladas** paso a paso sobre cada uno
 - ¡Manuales extremadamente detallados! (ASR, 😊 😊)
 - El software puede tener **perfiles de uso** (Ej.: ESTÁNDAR, MATERIAS CLASIFICADAS, USO OFICIAL...). ¿Por qué?
- Organizado en series en: <https://www.ccn-cert.cni.es/es/guias.htm>
 - Windows (serie 500), Otros SO (600), Software (800)...

CCN-STIC-570A23 Configuración de Seguridad para Windows Server

Paso	Descripción
2.	Ejecute el "Administrador del servidor", haciendo clic sobre el botón de "Inicio" y seleccionando el icono correspondiente. 
3.	En la parte superior derecha pulse sobre el botón "Herramientas" y a continuación seleccione "Administración de directivas de grupo". 

Nota: Si ha modificado o reubicado los accesos por defecto de Windows deberá hacer uso del buscador situado a la derecha del botón de "Inicio" para ejecutar el "Administrador del servidor".

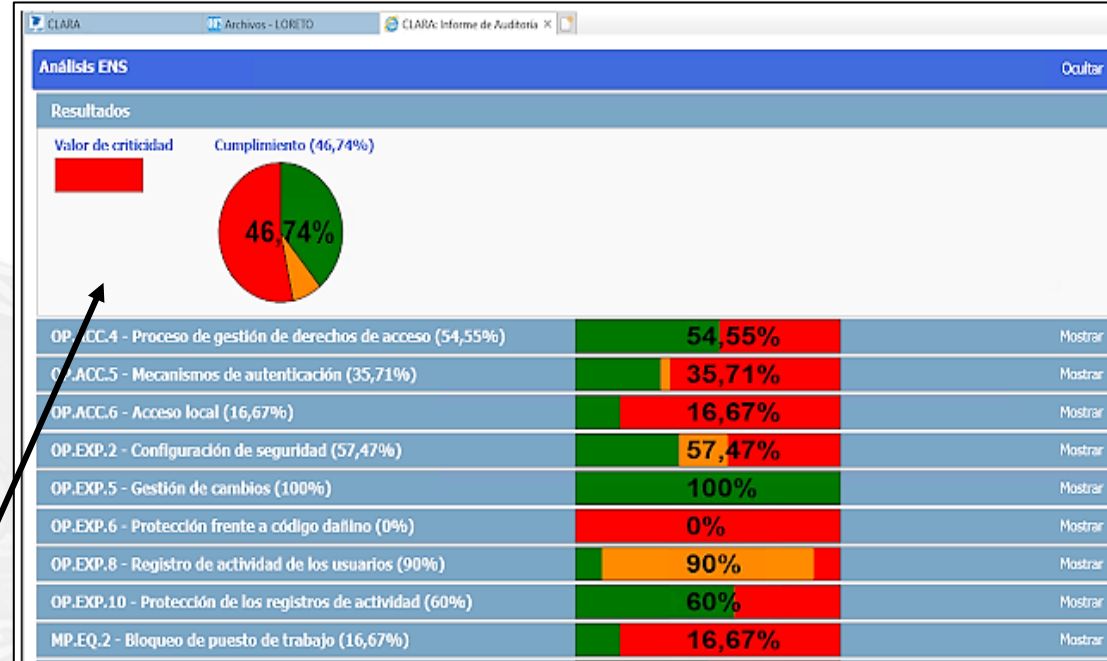
Fuente: <https://www.ccn-cert.cni.es/es/guias-de-acceso-publico-ccn-stic/7104-ccn-stic-570a23-perfilado-de-seguridad-para-windows-server-controlador-de-dominio-o-servidor-miembro/file.html>

ESQUEMA NACIONAL DE SEGURIDAD (ESPAÑA)



● CCN también ofrece software de seguridad

- <https://www.ccn-cert.cni.es/soluciones-seguridad.html>
- Uno es CLARA, para la verificación automatizada de cumplimiento de ENS (Windows/CentOS)
- **Tutorial:** <http://kinomakino.blogspot.com/2020/08/si-quieres-auditar-tu-windows-y-no-lo.html>



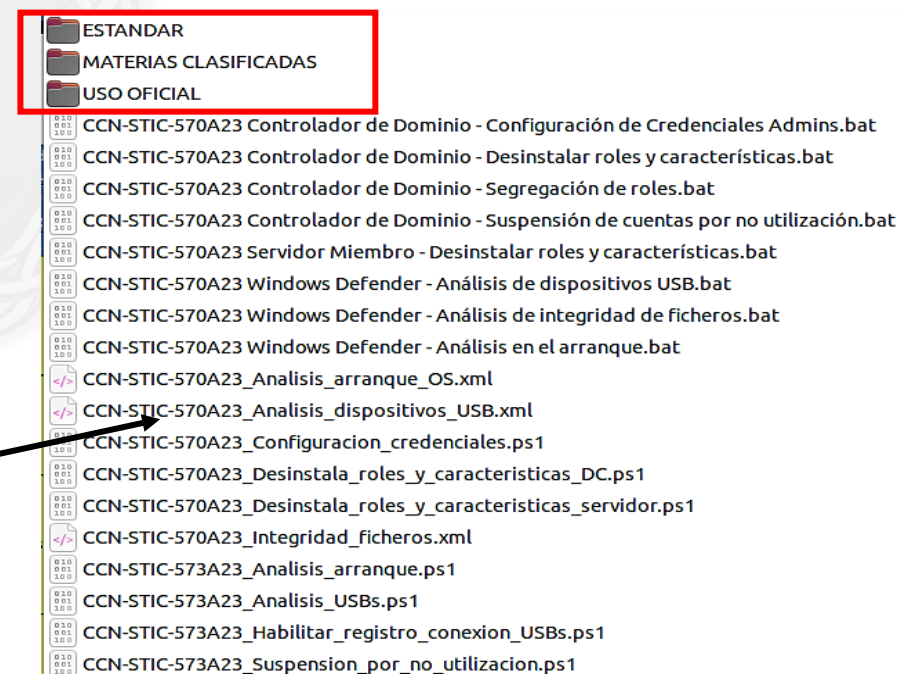
● Pero ENS no facilita el compliance as code

- No están estructurados como otras soluciones
 - Problema - descripción - comprobación - corrección
 - **Requieren una intervención manual importante**
- La corrección automatizada se hace **parcialmente** con **scripts** (.sh, .bat, .ps1...), no estandarizados

● ¿Existe un estándar para las 3 actividades principales de CaC?

- ¡Sí! ¡Veamos el protocolo SCAP! 😊

Scripts adaptados a los perfiles de la diapositiva anterior





Security Content Automation Protocol (SCAP)

Protocolo de automatización estandarizado para operaciones de fortalecimiento que facilitan el cumplimiento como código



SECURITY CONTENT AUTOMATION PROTOCOL (SCAP)



- **Estándar abierto del NIST para el CaC automatizado del software**
 - Las herramientas compatibles con SCAP cargan archivos en formatos XML
 - OVAL, XCCDF y Source Data Stream
 - Estas herramientas permiten **prevenir, detectar y remediar** (el trío del CaC)
 - **Configuración automatizada**, comprobación de vulnerabilidades y nivel de parches
 - Actividades para comprobar si se **cumplen** ciertos controles técnicos de seguridad
 - *¿Este control ya está implementado? -> ¿NO? -> Impleméntalo así*
 - Medición del **nivel de seguridad actual** (creación de informes)
 - A diferencia den ENS, **las operaciones se especifican en archivos XML abiertos**
- **OpenSCAP es su implementación de código abierto más popular**
 - Un conjunto de herramientas de código abierto que cumplen con SCAP 1.2
 - <https://www.open-scap.org/>
 - https://static.open-scap.org/openscap-1.3/oscap_user_manual.html
 - *Pero, si el estándar es abierto, ¿qué se podría hacer?*



ESTADO ACTUAL DE LA AUTOMATIZACIÓN DE LA SEGURIDAD



- **Al igual que en ENS, los archivos SCAP suelen definir sus propios **perfiles de uso****
 - Un mismo archivo puede definir **distintas listas de controles de seguridad** a comprobar o remediar
 - Dependiendo de **cómo vayamos a usar** el software (Ej.: servidor, estación de trabajo...)
- ***¿Cómo podemos tener listas de control de seguridad completas, adecuadas y compatibles con SCAP para todo software y SO que usemos?***
 - Creándolas a partir de descripciones de controles técnicos de seguridad fiables (Ej.: PDF) (tedioso)
 - Las descripciones son los requisitos, el análisis y el diseño (detallado); **Nosotros los implementamos**
 - **Usando fuentes adecuadas (fiables)** de archivos SCAP (siguiente sección)
 - Idealmente, gratis 😊
 - Estas son implementaciones de controles técnicos de seguridad que podemos **usar directamente** (o **adaptar** a nuestras necesidades)
 - **ENS no tiene este problema:** Todo está centralizado en su web oficial

¿CREES QUE LO HAS ENTENDIDO TODO? ¡EVALÚATE A TI MISMO!

● Puedes hacer lo siguiente

- *Comprender que la seguridad del software se puede administrar (y automatizar) con código*
- *Comprender que dicho código puede detectar y corregir problemas de configuración que pueden causar vulnerabilidades en su software relacionado*
- **Acerca del ENS**
 - *Entender que son una serie de principios y requisitos de seguridad de España*
 - *Saber qué incluyen sus guías de seguridad y para qué puedes usarlas*
 - *Comprender que no todas las máquinas de una infraestructura tienen la misma importancia, ya que existen perfiles de uso y categorías de configuración*
 - *Saber para qué puedes usar la herramienta ENS CLARA*
- **Acerca del protocolo SCAP**
 - *Entender que usa lenguajes XML: OVAL, XCCDF y Source Data Stream*
 - *Comprender que, gracias a él, puedes evaluar los sistemas, detectar qué controles de seguridad faltan y remediarlos*
 - *Y generar un informe sobre el estado de implementación de esos controles en el sistema*
 - *Que para ello se necesitan listas adecuadas de controles de seguridad (organizadas en perfiles)*





Fuentes de listas de controles de seguridad SCAP fiables

Algunas fuentes para obtener guías técnicas adecuadas (listas de controles de seguridad) para nuestro software



[SCAP Sec. Guide >](#)

[STIGs >](#)

[CIS Benchmarks >](#)



¿QUÉ VAS A ENCONTRARTE EN ESTE BLOQUE?

- **En la primera sección de este bloque, aprenderás**
 - Qué se incluye en el paquete **scap-security-guide** y sus perfiles de seguridad
 - Las diferentes formas de **usar los archivos** incluidos
 - Qué son los **informes de seguridad** que se obtienen al utilizar el protocolo SCAP
- **En el siguiente, aprenderás**
 - De dónde provienen los estándares **STIG** y su enfoque militar
 - Los **criterios** usados para subdividir los controles de seguridad STIG
 - Dónde puedes **descargar STIGs gratis** y las distintas partes de la definición de un **control de seguridad STIG**
- **Y, finalmente, en la última sección de este bloque aprenderás**
 - Qué son los **controles de seguridad del CIS** y quién los respalda
 - Que todas las instrucciones de implementación y su justificación **están gratis en PDF**
 - La **estructura general** de cualquier control CIS
 - Cómo lograr el **cumplimiento CIS automático y gratuito**



ACLARANDO LA IDEA BÁSICA DE LO QUE VEREMOS EN ESTA SECCIÓN

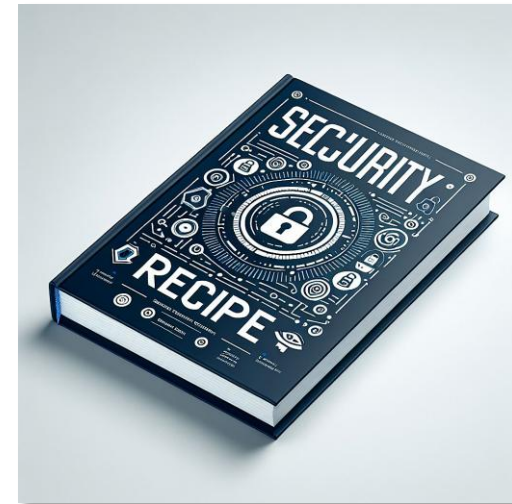


● Antes de empezar, debes entender

- Veremos sitios con **listas de controles técnicos de seguridad**
 - Cada una **relacionada con producto de software**
 - Los **controles técnicos de seguridad** son **comandos** de consola, **valores** en un archivo de configuración u **operaciones de GUI a implementar** en el software / SO relacionado
 - Las listas pueden tener **perfiles**: sublistas de controles de seguridad agrupados
- En cuanto a los **controles técnicos de seguridad**...
 - Por lo general, siguen un enfoque de **verificación – implementación – validación**
 - Cada uno que implementes te acerca a un **determinado estándar de seguridad**
 - La mayoría de los controles **se pueden automatizar** (implementar en código fuente)
- Por tanto, cada lista es un **programa para automatización de seguridad** de un producto
 - Los controles técnicos son las "**funciones**" de este programa
 - Los perfiles deciden a **qué "funciones" llamas finalmente**

● Esto es Compliance as Code

- Programas que hacen que un software esté **más cerca de cumplir** con un determinado estándar de seguridad
- **Pero no todo se puede automatizar...**



 [Índice](#) ->  [Automatización del hardening de seguridad](#) ->  [Fuentes de listas de controles de seguridad](#)



El paquete SCAP Security Guide (scap-security-guide)



EL PAQUETE SCAP-SECURITY-GUIDE

<https://www.open-scap.org/security-policies/scap-security-guide/>



● Listas de controles técnicos de seguridad creados por la comunidad compatibles con SCAP

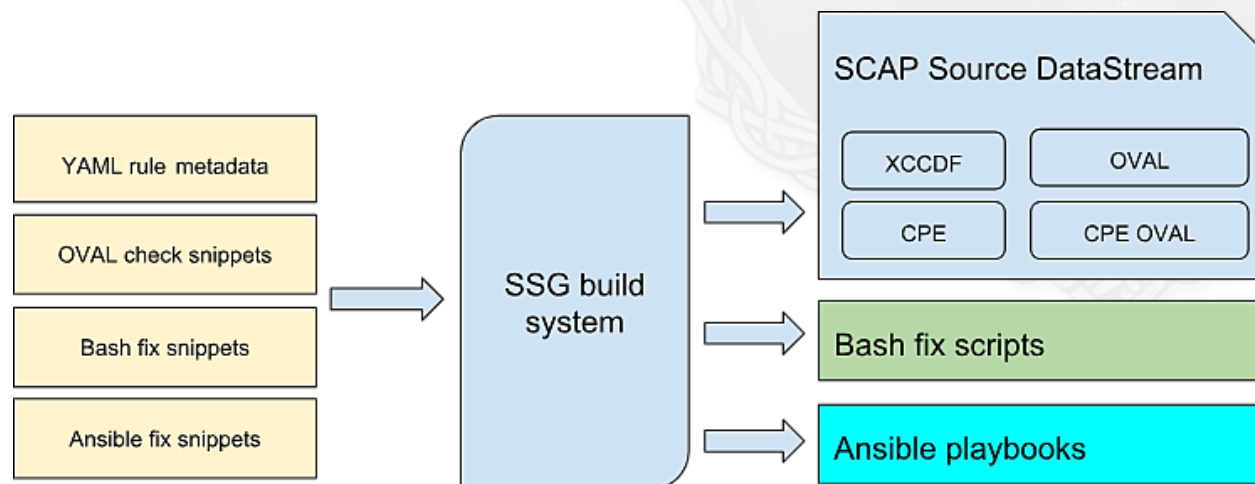
- Algunas se crean a partir de otras recomendaciones de seguridad (**CIS, STIG...**)
- Otras son **donadas** por empresas o gobiernos
- Sin embargo, suelen ser **menos completas y exhaustivas** (*¿adecuadas?*) que otras fuentes
 - La comunidad los actualiza con frecuencia con nuevos controles técnicos / perfiles de seguridad
 - Consulta <https://github.com/ComplianceAsCode/content>

● El paquete contiene

- La herramienta **oscap** (la implementación de OpenSCAP)
 - Funciona con **cualquier archivo SCAP**, no solo con los que suministra (**¡estándar abierto!** 😊)
- **Un conjunto de directivas de seguridad predefinidas compatibles con SCAP**
 - Pero solo para un **pequeño conjunto de programas** 😞
 - Principalmente para SO populares (Red Hat, Fedora, Ubuntu,...)

EL PAQUETE SCAP-SECURITY-GUIDE: REMEDIACIÓN

- Cada lista viene con tres formas de corrección automatizada del software/SO
 - Usar un archivo SCAP adecuado con la herramienta OpenSCAP
 - **Playbooks de Ansible** (<https://www.ansible.com/>): Ficheros **.yaml** para **automatizar la seguridad de muchos endpoints a la vez**
 - Es una herramienta popular de configuración automática de infraestructuras Windows / Linux
 - **Solo requiere acceso SSH** a cada endpoint remoto para implementar los controles técnicos de seguridad
 - ¿Quieres saber más? <https://ocw.uniovi.es/course/view.php?id=99>
 - **Scripts de Bash**: Para proteger un solo endpoint sin instalar nada (¡ni siquiera OpenSCAP!)



Hay tres formas de hacer remediación, y tú eliges la que más te convenga. **Algunas formas remedian más controles que otras**, aunque parten de la misma base. Los scripts de Bash se pueden copiar en cualquier máquina para ejecutarlos.

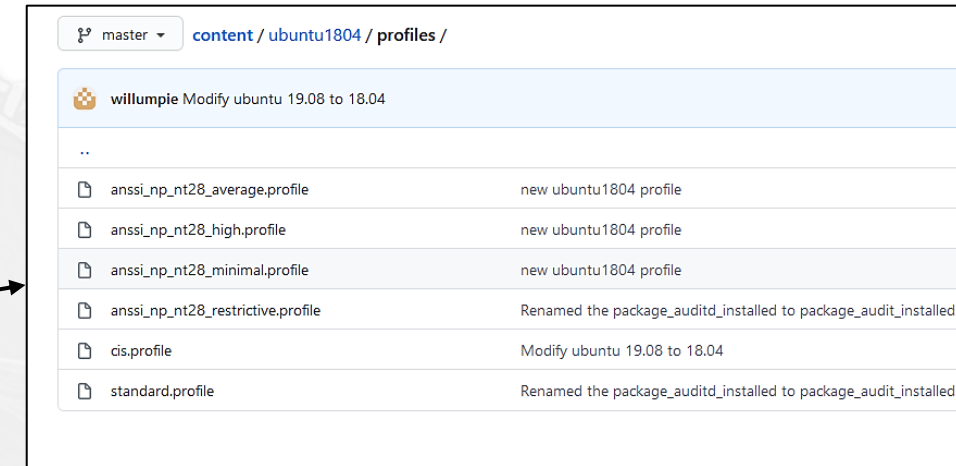
Ten mucho cuidado con la corrección automática: **podría romper algún servicio legítimo**

EL PAQUETE SCAP-SECURITY-GUIDE: PERFILES DE SEGURIDAD



● La imagen muestra los perfiles de seguridad SCAP del SO Ubuntu 18.04

- Un perfil de seguridad **standard**, que representa un nivel de seguridad mínimo
- 4 perfiles de la norma de seguridad ANSSI DAT-NT28
- Un perfil de seguridad basado en los controles de seguridad del CIS (visto luego)



master content / ubuntu1804 / profiles /	
willumpie Modify ubuntu 19.08 to 18.04	
..	
anssi_np_nt28_average.profile	new ubuntu1804 profile
anssi_np_nt28_high.profile	new ubuntu1804 profile
anssi_np_nt28_minimal.profile	new ubuntu1804 profile
anssi_np_nt28_restrictive.profile	Renamed the package_auditd_installed to package_audit_installed.
cis.profile	Modify ubuntu 19.08 to 18.04
standard.profile	Renamed the package_auditd_installed to package_audit_installed.

Archivos compatibles con SCAP (perfiles) disponibles por la comunidad como parte del paquete scap-

```
op@cr100server1664...etc/oscap/content/bash$ sudo bash ubuntu1804-script-standard.sh
```

● La 2ª imagen muestra la ejecución del contenido bash del perfil **standard**

● ¿Por qué algunos perfiles tienen más controles de seguridad que otros?

```
Remediating rule 22/45: 'package_rsyslog_installed'
FIX FOR THIS RULE 'package_rsyslog_installed' IS MISSING!
Remediating rule 23/45: 'service_rsyslog_enabled'
FIX FOR THIS RULE 'service_rsyslog_enabled' IS MISSING!
Remediating rule 24/45: 'file_groupowner_etc_group'
Remediating rule 25/45: 'file_groupowner_etc_gshadow'
Remediating rule 26/45: 'file_groupowner_etc_passwd'
Remediating rule 27/45: 'file_groupowner_etc_shadow'
Remediating rule 28/45: 'file_owner_etc_group'
Remediating rule 29/45: 'file_owner_etc_gshadow'
Remediating rule 30/45: 'file_owner_etc_passwd'
Remediating rule 31/45: 'file_owner_etc_shadow'
Remediating rule 32/45: 'file_permissions_etc_group'
Remediating rule 33/45: 'file_permissions_etc_gshadow'
Remediating rule 34/45: 'file_permissions_etc_passwd'
Remediating rule 35/45: 'file_permissions_etc_shadow'
Remediating rule 36/45: 'file_permissions_systemmap'
FIX FOR THIS RULE 'file_permissions_systemmap' IS MISSING!
Remediating rule 37/45: 'logctl_fc_protected_hardlinks'
```

EL PAQUETE SCAP-SECURITY-GUIDE: INFORMES DE SEGURIDAD



- La herramienta **oscap** puede crear informes HTML
 - Contiene los controles de seguridad que el software relacionado ya implementa (o no)
 - Algunos **no pueden determinarse** (requieren **verificación manual**)
 - De los que no lo hacen, indica su **gravedad**
 - La importancia de los controles que faltan
 - Muestra un % de cumplimiento (**puntuación de seguridad**)
 - Y finalmente, una **lista detallada** de cada control
 - Cuyas entradas se pueden abrir para saber sus detalles

Compliance and Scoring

The target system did not satisfy the conditions of 34 rules! Furthermore, the results of 1 rules were inconclusive. Please review rule results and consider applying remediation.

Rule results



Severity of failed rules



Score

Scoring system	Score	Maximum	Percent
urn:xccdf:scoring:default	67.276932	100.000000	67.28%

Rule Overview

☒ pass ☒ fail ☒ notchecked
☒ fixed ☒ error ☒ notapplicable
☒ informational ☒ unknown Group rules by: Default

Title	Severity	Result
▼ Guide to the Secure Configuration of Red Hat Enterprise Linux 7	34x fail 1x unknown 1x notchecked	
▼ System Settings	26x fail 1x unknown 1x notchecked	
▼ Installing and Maintaining Software	7x fail 1x notchecked	
▼ Disk Partitioning	4x fail	
Ensure /tmp Located On Separate Partition	low	fail
Ensure /var Located On Separate Partition	low	fail

Es muy interesante crear un informe antes de la remediación y otro después, para comparar puntuaciones y lo que se ha remediado automáticamente con estas herramientas

¿CREES QUE LO HAS ENTENDIDO TODO? ¡EVALÚATE A TI MISMO!



?

● Puedes hacer lo siguiente

- *Comprender que el paquete `scap-security-guide` es básicamente una fuente gratuita y abierta de listas de controles de seguridad para, mayoritariamente, ciertos tipos de SO*
- *Entender que no todos los controles de seguridad incluidos tienen la corrección de OSCAP disponible en un momento dado*
 - *Pero esa corrección se podría implementar en los archivos `Ansible` y / o `bash` que también se incluyen en los perfiles de paquetes `scap-security-guide`*
- *Comprender que cada archivo SCAP distribuido puede tener diferentes perfiles de seguridad aplicables al producto en el que está trabajando*
 - *Y que estos perfiles cambian según el producto*
- *Interpretar la estructura de un informe SCAP generado para un software evaluado*
 - *Dónde está su índice de seguridad general*
 - *Qué controles de seguridad cumple y cuáles no*

 [Índice](#) ->  [Automatización del hardening de seguridad](#) ->  [Fuentes de listas de controles de seguridad](#)



Security Technical Implementation Guides (STIGs)



NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY (NIST)

<https://www.nist.gov/> <https://www.cyber.mil/stigs>



- **Archivo/repositorio STIG gratuito y público** <https://www.cyber.mil/stigs>
 - 560+ "benchmarks de seguridad" (**listas de controles técnicos de seguridad**) para muchos productos
 - Muchos de ellos también son compatibles con SCAP: <https://public.cyber.mil/stigs/scap/>
 - Para cada tipo de dispositivo o software, su STIG contiene **100s de controles técnicos de seguridad**
 - Para determinar si cumplen con el estándar de seguridad especificado por el STIG
 - Ej.: Windows Server 2022 STIG especifica cómo configurar contraseñas, permisos de usuario, auditoría...
- **Usados por el Departamento de Defensa de EE. UU. (DOD) y la Agencia de Sistemas de Información de Defensa (DISA)**
 - Por lo tanto, podrían considerarse **controles de seguridad de grado militar**
 - Su herramienta **SCAP oficial pública** (SCC, SCAP Compliance Checker) está **limitada a solo auditoría (informes)**
 - La corrección automatizada de la mayoría de los STIG son implementaciones de 3ºs (Ej.: Ubuntu Pro)
 - Se ofrece de forma gratuita para algunos productos con Ansible

CATEGORÍAS STIG (NIVELES DE GRAVEDAD)

- A cada **control técnico de seguridad** se le da un nivel de gravedad con categorías
- Si un control no se corrige, puede causar una vulnerabilidad cuya explotación...
 - CAT I: ... causa directamente una pérdida de CIA (muy grave)
 - CAT II: ... puede causar potencialmente una pérdida de CIA (intermedio)
 - CAT III: ... provoca una degradación de las medidas que evitan la pérdida de CIA (menos grave)

La herramienta de auditoría de seguridad STIG de Tenable analizando varios endpoints que no pasan los controles técnicos de seguridad de diferentes clasificaciones CAT.

Fuente: <https://www.tenable.com/sc-dashboards/stig-alerts-by-cat>

tenable.sc

Dashboard ▾

Analysis ▾

Scans ▾

Reporting ▾

Assets

Workflow ▾

STIG Alerts (CAT) Switch Dashboard ▾

STIG Alerts (CAT) - Audits Performed

Scan Results	Last 7 Days	Last 30 Days	Over 30 Days
	None		None

Last Updated: 2 hours ago

STIG Alerts (CAT) - DISA Severity Level - III

	Audits Present	Total	Passing Totals	Failing Totals	Pass Ratio
CAT I		898	532	154	78%
CAT II		8543	4261	3451	55%
CAT III		1799	621	1077	37%

Last Updated: 2 hours ago

STIG Alerts (CAT) - IP Summary (Pass/Fail)

IP Address	DNS	Score	Repository	Total	Vulnerabilities
192.168.1.0/24	LaptopOne	140	JWDCO/InterOperability Lab	21	
172.20.0.0/24	solaris11.targ	2670	Offline - (Dedicated Targets)	663	357 306
172.20.0.0/24	solaris10.1ar	2560	Offline - (Dedicated Targets)	706	256 450
172.20.0.0/24	solaris9.targ	2680	Offline - (Dedicated Targets)	705	298 407

Last Updated: 4 hours ago

STIG Alerts (CAT) - Networks with Failed Audit Results

IP Address	Repository	Total
192.168.1.0/24	JWDCO/InterOperability Lab	14
172.20.0.0/24	Offline - (Dedicated Targets)	4668

Last Updated: 4 hours ago

STIG Alerts (CAT) - Failing Items Summary

Plugin ID	Name	Severity	Total
1003143	GEN008500 - The system must have IEEE 1394 (Firewire) disabled unless needed.	High	11
1003138	GEN006565 - The system package management tool must be used to verify system software periodically.	High	11
1003121	GEN003540 - The system must implement non-executable program stacks.	High	11
1003093	GEN000452 - The system must display the date and time of the last successful account login upon login.	High	11
1002978	GEN007950 - The system must not respond to ICMPv6 echo requests sent to a broadcast address.	High	11
1002975	GEN007860 - The system must ignore IPv6 ICMP redirect messages.	High	11

NIVELES DE MACs Y CONFIDENCIALIDAD DE LA INFORMACIÓN



- Todos los **sistemas** cuyo software se está securizando con STIG también se clasifican utilizando un nivel Mission Assurance Category (MAC)
- Basado en la importancia de la información que manejan y cuán crítica es
 - **MAC I:** Sistemas que gestionan **información vital** para garantizar la eficacia de su funcionalidad
 - Perder uno es **inaceptable**, tienen las **medidas de seguridad más fuertes**
 - **MAC II:** Sistemas que gestionan **información importante** para la funcionalidad realizada
 - Perder uno es un **problema importante**, implementa **medidas de seguridad de nivel medio**
 - **MAC III:** Sistemas que gestionan la **información necesaria (pero no crítica)** para la actividad diaria del sistema
 - Perder uno es **aceptable**, su seguridad se basa en **mejores prácticas de gestión**
- También hay tres niveles para clasificar la confidencialidad de la información
 - Definido por el DoDI 8500.2: https://fas.org/irp/doddir/dod/d8500_2.pdf: **Classified, Sensitive, Public**
- Los niveles de MAC y confidencialidad son independientes

EJEMPLO. STIG "CANONICAL UBUNTU 20.04 LTS": PERFILES

- Todos los controles de un STIG se agrupan por su CAT
 - En este ejemplo, 13 CAT I, 133 CAT II y 21 CAT III
- Cada STIG tiene 9 perfiles de aplicación
 - 3 niveles de confidencialidad por cada MAC (3x3)
 - Al seleccionar uno, cambia el número de controles que se realizarán en cada CAT
 - Y, por tanto, **la cantidad de controles técnicos de seguridad** en la lista para detectar y remediar 😊
- También tenemos **descargas**
 - XML/JSON para comprobar automáticamente, **con las herramientas adecuadas**, si se cumple este nivel
 - Un archivo de Excel (**.csv**) para facilitar las **comprobaciones manuales**

Fuente: https://www.stigviewer.com/stig/canonical_ubuntu_20.04_lts/

Version	Date	Finding Count (167)			Downloads		
1	2022-06-06 	CAT I (High): 13	CAT II (Med): 133	CAT III (Low): 21	Excel 	JSON 	XML 
STIG Description							
This Security Technical Implementation Guide is published as a tool to improve the security of Department of Defense (DoD) information systems. The requirements are derived from the National Institute of Standards and Technology (NIST) 800-53 and related documents. Comments or proposed revisions to this document should be sent via email to the following address: disa.stig_spt@mail.mil.							
Available Profiles 							
Classified	Public	Sensitive					
I - Mission Critical Classified	I - Mission Critical Public	I - Mission Critical Sensitive	II - Mission Support Classified	II - Mission Support Public	II - Mission Support Sensitive	III - Administrative Classified	III - Administrative Public
						III - Administrative Sensitive	

EJEMPLO: STIG "CANONICAL UBUNTU 20.04 LTS": LISTAS DE CONTROLES DE SEGURIDAD DE LOS PERFILES



- Primero se debe elegir una combinación de perfil MAC-confidencialidad
- Luego el STIG presenta su lista relacionada de controles de seguridad
- Cada entrada tiene
 - **Finding ID:** ID de control único
 - **Gravedad:** De la vulnerabilidad asociada si se descubre en el sistema auditado
 - **Título:** Resumen de los objetivos de control
 - **Descripción:** Descripción detallada de los efectos o particularidades del control
- Si hacemos clic en cada ID de control de seguridad, podemos ver sus detalles

Findings (MAC III - Administrative Sensitive)				Un control técnico de seguridad STIG
Finding ID	Severity	Title	Description	
V-238204	High	Ubuntu operating systems when booted must require authentication upon booting into single-user and maintenance modes.	To mitigate the risk of unauthorized access to sensitive information by entities that have been issued certificates by DoD-approved PKIs, all DoD systems (e.g., web servers and web portals) must...	
Detalles				
V-238206	High	The Ubuntu operating system must ensure only users who need access to security functions are part of the sudo group.	An isolation boundary provides access control and protects the integrity of the hardware, software, and firmware that perform security functions. Security functions are the hardware, software,...	
V-238201	High	The Ubuntu operating system must map the authenticated identity to the user or group account for PKI-based authentication.	Without mapping the certificate used to authenticate to the user account, the ability to determine the identity of the individual user or group will not be available for forensic analysis.	
V-238363	High	The Ubuntu operating system must implement NIST FIPS-validated cryptography to protect classified information and for the following: to provision digital signatures, to generate cryptographic hashes, and to protect unclassified information requiring confidentiality and cryptographic protection in accordance with applicable federal laws, Executive Orders, directives, policies, regulations, and standards.	Use of weak or untested encryption algorithms undermines the purposes of utilizing encryption to protect data. The operating system must implement cryptographic modules adhering to the higher...	
V-238219	High	The Ubuntu operating system must be configured so that remote X connections are disabled, unless to fulfill documented and validated mission requirements.	The security risk of using X11 forwarding is that the client's X11 display server may be exposed to attack when the SSH client requests forwarding. A System Administrator may have a stance in...	
V-238218	High	The Ubuntu operating system must not allow unattended or automatic login via SSH.	Failure to restrict system access to authenticated users negatively impacts Ubuntu operating system security.	

Fuente: https://www.stigviewer.com/stig/canonical_ubuntu_20.04_lts/2022-06-06/MAC-3_Sensitive/

STIG "CANONICAL UBUNTU 20.04 LTS": INFORMACIÓN DETALLADA DEL CONTROL INDIVIDUAL



- La descripción detallada de cada control técnico de seguridad nos dice
 - **Cómo verificar** si el control técnico de seguridad ya está implementado
 - **Cómo implementarlo** si no lo está
 - En el ejemplo, verá comandos de consola reales
 - Además, una explicación de los posibles resultados y su significado exacto
 - ¡No queda **nada** para la interpretación!

The Ubuntu operating system must use SSH to protect the confidentiality and integrity of transmitted information.

Overview

Finding ID	Version	Rule ID	IA Controls	Severity
V-238215	UBTU-20-010042	SV-238215r653820_rule		High

Description

Without protection of the transmitted information, confidentiality and integrity may be compromised because unprotected communications can be intercepted and either read or altered. This requirement applies to both internal and external networks and all types of information system components from which information can be transmitted (e.g., servers, mobile devices, notebook computers, printers, copiers, scanners, and facsimile machines). Communication paths outside the physical protection of a controlled boundary are exposed to the possibility of interception and modification. Protecting the confidentiality and integrity of organizational information can be accomplished by physical means (e.g., employing physical distribution systems) or by logical means (e.g., employing cryptographic techniques). If physical means of protection are employed, then logical means (cryptography) do not have to be employed, and vice versa. Satisfies: SRG-OS-000423-GPOS-00187, SRG-OS-000425-GPOS-00189, SRG-OS-000426-GPOS-00190

STIG

[Canonical Ubuntu 20.04 LTS Security Technical Implementation Guide](#)

Date

2022-06-06

Details

Check Text (C-41425r653818_chk)

Verify the SSH package is installed with the following command:

```
$ sudo dpkg -l | grep openssh
```

```
ii openssh-client 1:7.6p1-4ubuntu0.1 amd64 secure shell (SSH) client, for secure access to remote machines
ii openssh-server 1:7.6p1-4ubuntu0.1 amd64 secure shell (SSH) server, for secure access from remote machines
ii openssh-sftp-server 1:7.6p1-4ubuntu0.1 amd64 secure shell (SSH) sftp server module, for SFTP access from remote machines
```

If the "openssh" server package is not installed, this is a finding.

Verify the "sshd.service" is loaded and active with the following command:

Fuente: https://www.stigviewer.com/stig/canonical_ubuntu_20.04_lts/2022-06-06/finding/V-238215

¿CREEES QUE LO HAS ENTENDIDO TODO? ¡EVALÚATE A TI MISMO!



● Puedes hacer lo siguiente

- *Comprender que los STIG son las listas de controles de seguridad usadas por el Departamento de Defensa de los EE. UU. y que muchas de ellas se distribuyen en formato SCAP*
- *Entender que a cada control de seguridad se le asigna un nivel de seguridad en función de la criticidad de la vulnerabilidad que podría provocar que no se implemente (clasificación CAT)*
- *Saber que los sistemas se clasifican según la importancia de la información que manejan (clasificación MAC)*
- *Saber que la información que manejan estos sistemas también se clasifica según su confidencialidad*
- *Entender que los niveles de MAC y confidencialidad son independientes*
- *Saber que muchos STIG son gratuitos e incluso la herramienta oficial de auditoría del sistema (SCC) está disponible para algunos sistemas operativos (también de forma gratuita)*
- *Comprender la estructura general de un control de seguridad STIG*



 [Índice](#) ->  [Automatización del hardening de seguridad](#) ->  [Fuentes de listas de controles de seguridad](#)



Benchmarks del Center for Internet Security (CIS)



- **Guías de hardening de referencia mundial para 100+ de software populares**
 - Listas recomendadas de **controles técnicos de seguridad**
- **Creados y usados por consenso de gobiernos y muchas empresas importantes**
 - Lo que **garantiza la calidad y fiabilidad de sus contenidos...**
 - Contienen los conocimientos más actualizados y las mejores prácticas de seguridad
- **Aparte de las guías, incluyen (no gratis)**
 - MV reforzadas prediseñadas en Azure, AWS, Google Cloud; *¿Cuál es la ventaja de usarlas?*
 - <https://www.cisecurity.org/cis-hardened-image-list>
 - Kits para automatizar la configuración del software existente de acuerdo con su benchmark
 - <https://www.cisecurity.org/cis-securesuite/cis-securesuite-build-kit-content>
- **Los CIS Benchmarks están relacionados con STIG**
 - Mapeo STIG <-> CIS Benchmarks: <https://www.cisecurity.org/blog/new-options-from-cis-for-stig-compliance/>

CIS BENCHMARKS



- **Gratis en formato PDF (registro opcional)**

- <https://downloads.cisecurity.org/#/>

- **También disponible en formatos SCAP**

- Con su propia herramienta SCAP (CIS CAT Pro):
 - <https://www.cisecurity.org/cybersecurity-tools/cis-cat-pro>
 - Pero no gratis ☹️
- Existe una versión gratuita limitada
 - CIS-CAT Lite: <https://learn.cisecurity.org/cis-cat-lite>

Source: <https://www.cisecurity.org/cis-benchmarks/>

Operating Systems Server Software Cloud Providers Mobile Devices Network Devices Desktop Software

Currently showing ALL Technologies. Use the buttons above to filter the list.

Cloud Providers **Alibaba Cloud** Expand to see related content Download CIS Benchmark →

Operating Systems **Aliyun Linux** Expand to see related content Download CIS Benchmark →
Linux Build Kit also available

Operating Systems **AlmaLinux OS** Expand to see related content Download CIS Benchmark →
Linux CIS Hardened Image also available

Operating Systems **Amazon Linux** Expand to see related content Download CIS Benchmark →
Linux CIS Hardened Image and Build Kit also available

CIS Microsoft Windows 10 Enterprise Release 21H1 Benchmark v1.11.0

Level 1 (L1) - Corporate/Enterprise Environment (general use)

Summary

Description	Tests				Scoring			
	Pass	Fail	Error	Unkn.	Man.	Score	Max	Percent
1 Account Policies	3	5	0	2	0	3.0	10.0	30%
1.1 Password Policy	1	4	0	2	0	1.0	7.0	14%
1.2 Account Lockout Policy	2	1	0	0	0	2.0	3.0	67%
2 Local Policies	76	21	0	1	1	76.0	98.0	78%
2.1 Audit Policy	0	0	0	0	0	0.0	0.0	0%
2.2 User Rights Assignment	32	5	0	0	0	32.0	37.0	86%
2.3 Security Options	44	16	0	1	1	44.0	61.0	72%
2.3.1 Accounts	6	0	0	0	0	6.0	6.0	100%
2.3.2 Audit	2	0	0	0	0	2.0	2.0	100%
19.7.42 Windows Hello for Business (formerly Microsoft Passport for Work)	0	0	0	0	0	0.0	0.0	0%
19.7.43 Windows Installer	1	0	0	0	0	1.0	1.0	100%
19.7.44 Windows Logon Options	0	0	0	0	0	0.0	0.0	0%
19.7.45 Windows Mail	0	0	0	0	0	0.0	0.0	0%
19.7.46 Windows Media Center	0	0	0	0	0	0.0	0.0	0%
19.7.47 Windows Media Player	0	0	0	0	0	0.0	0.0	0%
19.7.47.1 Networking	0	0	0	0	0	0.0	0.0	0%
19.7.47.2 Playback	0	0	0	0	0	0.0	0.0	0%
Total	226	102	0	3	1	226.0	331.0	68%

ESTRUCTURA DE LOS CONTROLES DE SEGURIDAD



● Anatomía de un control técnico de seguridad CIS

- **Automatizado o manual**
- **Niveles** (1, 2, especial)
- **Perfiles** (Servidor, Estación de trabajo...): Grupos de controles técnicos de seguridad, según software asociado
- **Descripción** (breve)
- **Justificación** (*¿Por qué es esto necesario?*)
- **Impacto** (posibles problemas de implementación)
- **Auditoría** (verificación / validación de control)
- **Corrección** (implementación del control)
- **Referencias e información adicional**

● ¡También pueden funcionar como material de formación!

5.3.3 Ensure sudo log file exists (Automated)

Profile Applicability:

- Level 1 - Server
- Level 1 - Workstation

Fuente: PDF del Ubuntu
22.04 Benchmark

Description:

sudo can use a custom log file

Rationale:

A sudo log file simplifies auditing of sudo commands

Impact:

WARNING: Editing the `sudo` configuration incorrectly can cause `sudo` to stop functioning. Always use `visudo` to modify `sudo` configuration files.

Audit:

Run the following command to verify that sudo has a custom log file configured:

```
# grep -rPsi  
"^\\h*Defaults\\h+([\\#]+,\\h*)?logfile\\h*=\\h*(\\\"|\\')?\\h+([\\\"|\\')?(,\\h*\\h+\\h*)*\\h+  
(#.+)?$\" /etc/sudoers*
```

Verify the output matches:

```
Defaults logfile=\"/var/log/sudo.log\"
```

Remediation:

Edit the file `/etc/sudoers` or a file in `/etc/sudoers.d/` with `visudo` or `visudo -f <PATH TO FILE>` and add the following line:

Example:

```
Defaults logfile=\"/var/log/sudo.log\"
```

References:

1. SUDO(8)
2. VISUDO(8)

Additional Information:

`visudo` edits the `sudoers` file in a safe fashion, analogous to `vipw(8)`. `visudo` locks the `sudoers` file against multiple simultaneous edits, provides basic sanity checks, and checks for parse errors. If the `sudoers` file is currently being edited you will receive a message to try again later.

LICENCIA UBUNTU PRO Y LA AUTOMATIZACIÓN DE WINDOWS

<https://ubuntu.com/pro>



● Convierte a Ubuntu en un sistema Linux de nivel empresarial

- 10 años de soporte de paquetes
- Acceso a Ubuntu Security Guide (paquete **usg**)
 - Incluye **cumplimiento automatizado para Ubuntu, CIS y DISA STIG**
 - **CIS:** <https://ubuntu.com/security/certifications/docs/usg/cis>
 - **DISA STIG:** <https://ubuntu.com/security/certifications/docs/disa-stig>
- Requiere registro, y es gratis para hasta 5 Ubuntu 18.04LTS+



● Microsoft publica sus propios baseline de seguridad y software de automatización

- Controles técnicos de seguridad a implementar, pero **con su propio estándar** (ni CIS ni STIG)
- <https://learn.microsoft.com/es-es/windows/security/threat-protection/windows-security-configuration-framework/windows-security-baselines>

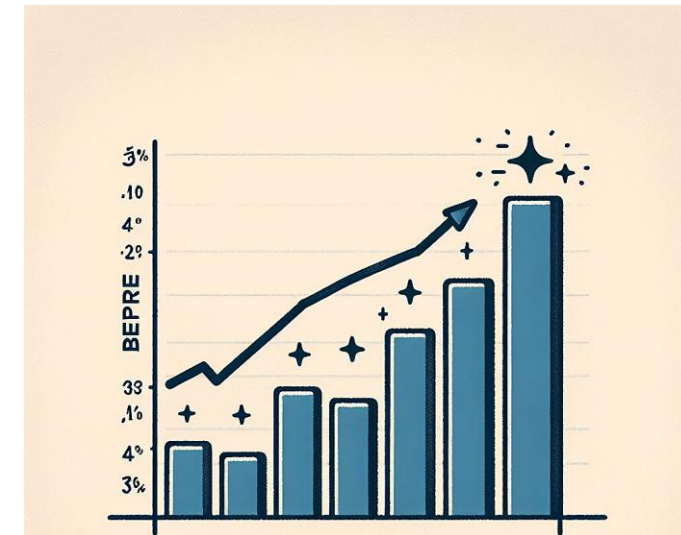
● Hay otras implementaciones no oficiales de terceros

- Son potencialmente peligrosos; *¿Por qué?*

IMPLEMENTACIÓN Y EVALUACIÓN DE LA SEGURIDAD

● Debes extraer los siguientes puntos clave

- Cierta software popular tiene asociadas **listas de controles técnicos de seguridad** que mejoran su seguridad
- La **máxima seguridad** solo se puede lograr si estas listas están validadas y son completas (**fuentes adecuadas**)
- Muchos de estos controles técnicos de seguridad pueden comprobarse y aplicarse **automáticamente**
- La automatización significa que se puede mejorar sustancialmente el nivel de seguridad de cualquier software **con poco esfuerzo**
- Pero, *¿cuánto?* Esto se puede medir con...
 - Los **informes** generados por las **herramientas compatibles con SCAP** ofrecen un % de cumplimiento
 - **Herramientas automatizadas de evaluación de seguridad:** Lynis, CLARA...
- *¿Podemos medir de forma fiable la mejora de la seguridad de un CIS o un STIG benchmark con una herramienta independiente como Lynis? ¿De qué depende?*



¿CREEES QUE LO HAS ENTENDIDO TODO? ¡EVALÚATE A TI MISMO!



?

● Puedes hacer lo siguiente

- *Comprender qué son los CIS Benchmarks, quién los mantiene y desde dónde se pueden descargar*
- *Comprender el significado de un control de seguridad clasificado como automatizado frente a uno clasificado como manual*
- *Comprender qué son los perfiles de uso y que dependen de cada software*
- *Comprender la diferencia entre un control técnico CIS de Nivel 1 y Nivel 2*
- *Comprender qué información puedes encontrar en las secciones de descripción, justificación, auditoría y corrección de cada control*
- *Conocer lo que ofrece la licencia de Ubuntu Pro con respecto a CIS (y STIG)*
- *Saber que hay formas de lograr el cumplimiento CIS con herramientas de terceros, pero entendiendo los riesgos involucrados*



PARA TENER UN SISTEMA SECURIZADO DEBERÍAMOS...

● Por tanto, los principios para tener un sistema seguro son

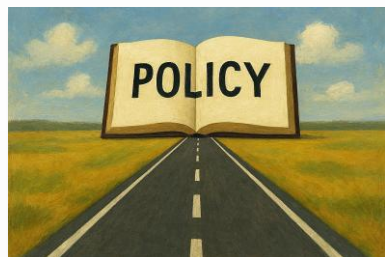
- **Aislamiento:** Trabaja solo con MV aisladas siempre que sea posible
 - Permite replicar fácilmente entornos de trabajo
- Trabaja siempre con un **usuario sin privilegios** (ni siquiera sudoer)
 - Ten una cuenta de administrador secundaria solo para tareas administrativas
- Instala **la menor cantidad de software posible**
 - Y siempre de fuentes fiables/oficiales
 - Si es necesario navegar, protege tu navegador (**Laboratorio 2**)
- **Actualiza** automáticamente tu software
- **Securiza** cada software con listas de controles técnicos adecuados
 - Automatízalo tanto como sea posible
 - *¿Cómo puedes mezclar esto con MVs para lograr la máxima ventaja?*
- Usa una herramienta **antimalware** adecuada
- **Supervisa las MV** con un EDR/XDR externo (Ej.: Wazuh)

● Y ahora, ¡vayamos más alto!



¿Has considerado que puedes crear MVs especializadas a partir de una MV base reforzada con un SO "pelado"? (para navegar, desarrollar...). Así puedes tener un entorno aislado especializado para todo. ¡Y esa es la forma más segura de trabajar!

[< Ir al índice](#)



EL CAMINO HACIA LAS POLÍTICAS DE SEGURIDAD

Cómo convertir los controles técnicos de seguridad
en algo más...



Departamento de Informática
Universidad de Oviedo



Universidad de Oviedo

¿QUÉ VAS A ENCONTRARTE EN ESTE BLOQUE?

- **La sección anterior se centró en dos elementos clave para lograr una seguridad adecuada con menos esfuerzo**
 - **Listas de controles de seguridad validados**, debidamente **documentados y mantenidos**
 - Para cualquier **software / SO** que necesitemos securizar y del que tenemos listas disponibles
 - Una forma de **automatizar su verificación y/o implementarlos**
- **Ahora relacionaremos estas listas de control técnico de seguridad con elementos de un nivel de abstracción superior**
 - Como políticas de seguridad, marcos y Sistemas de Gestión de Seguridad de la Información (SGSI) (ISMS en inglés)
- **Así sabremos cómo desde la parte técnica de bajo nivel podemos pasar a técnicas de gestión de seguridad más abstractas**
 - Desde la "consola hasta la documentación" (que contiene una política de seguridad), y todo lo demás "en medio" 😊





Controles de seguridad (No técnicos)

Representación de operaciones de seguridad en controles de seguridad de nivel de abstracción superior



MÁS ALLÁ DE LOS CONTROLES TÉCNICOS DE SEGURIDAD

- Implementar listas de controles técnicos de seguridad adecuados en todo el software que usemos es clave para lograr la mejor seguridad posible
 - Pero *¿qué pasa si trabajamos con cientos de endpoints, programas, etc.?*
- Necesitamos abstracciones mayores que agrupen los controles de seguridad en **menos entidades**
 - En un **nivel de abstracción más alto**, necesitamos cosas como *"Las contraseñas deben cumplir con un estándar alto de seguridad"*
 - **No acciones técnicas de bajo nivel** (los controles técnicos de seguridad anteriores). Por ejemplo:
 - Ej.: Instalar el paquete **libpam** de Linux, poner un valor en un archivo de un controlador de dominio Windows...
 - Necesitamos algo que **nos aísle de los detalles técnicos** de cada sistema
 - Centrarse en **"qué"** en lugar de **"cómo"** (*¿Windows? ¿Linux? ¡No importa!*)
- CIS (y otros) te permiten alcanzar un nivel de abstracción más alto
 - Con sus 18 **Critical Security Controls** (CSC), más abstractos
 - 18 abstracciones **"qué"** agrupan 100s de controles técnicos de seguridad **"cómo"**



CIS CRITICAL SECURITY CONTROLS (CSC CONTROLS) v8



- Todos los aspectos de ciberseguridad divididos en 18 grupos de alto nivel
 - También **subdividido** en 153 Safeguards/Salvaguas (menos abstractas, **nunca técnicas**)
 - No te vas a encontrar con un comando bash o PowerShell en ellos...
- **Ventajas**
 - Diseñados para mitigar los principales ataques a endpoints (y redes, **Tema 6**)
 - Mapeable (y referido por) múltiples marcos legales, de gestión y de seguridad
 - Basado en la **experiencia real** y las **amenazas más recientes**
 - Cloud, virtualización, ataques de trabajo remoto, nuevas tácticas de ataque...

CONTROL 01 Inventory and Control of Enterprise Assets 5 Safeguards IG1 2/5 IG2 4/5 IG3 5/5	CONTROL 02 Inventory and Control of Software Assets 7 Safeguards IG1 3/7 IG2 6/7 IG3 7/7	CONTROL 03 Data Protection 14 Safeguards IG1 6/14 IG2 12/14 IG3 14/14
CONTROL 04 Secure Configuration of Enterprise Assets and Software 12 Safeguards IG1 7/12 IG2 11/12 IG3 12/12	CONTROL 05 Account Management 6 Safeguards IG1 4/6 IG2 6/6 IG3 6/6	CONTROL 06 Access Control Management 8 Safeguards IG1 5/8 IG2 7/8 IG3 8/8
CONTROL 07 Continuous Vulnerability Management 7 Safeguards IG1 4/7 IG2 7/7 IG3 7/7	CONTROL 08 Audit Log Management 12 Safeguards IG1 3/12 IG2 11/12 IG3 12/12	CONTROL 09 Email and Web Browser Protections 7 Safeguards IG1 2/7 IG2 6/7 IG3 7/7
CONTROL 10 Malware Defenses 7 Safeguards IG1 3/7 IG2 7/7 IG3 7/7	CONTROL 11 Data Recovery 5 Safeguards IG1 4/5 IG2 5/5 IG3 5/5	CONTROL 12 Network Infrastructure Management 8 Safeguards IG1 1/8 IG2 7/8 IG3 8/8
CONTROL 13 Network Monitoring and Defense 11 Safeguards IG1 0/11 IG2 6/11 IG3 11/11	CONTROL 14 Security Awareness and Skills Training 9 Safeguards IG1 8/9 IG2 9/9 IG3 9/9	CONTROL 15 Service Provider Management 7 Safeguards IG1 1/7 IG2 4/7 IG3 7/7
CONTROL 16 Applications Software Security 14 Safeguards IG1 0/14 IG2 11/14 IG3 14/14	CONTROL 17 Incident Response Management 9 Safeguards IG1 3/9 IG2 8/9 IG3 9/9	CONTROL 18 Penetration Testing 5 Safeguards IG1 0/5 IG2 3/5 IG3 5/5

Organización general de los 18 controles CSC v8 y sus 153 salvaguardas: <https://www.linkedin.com/pulse/cis-critical-security-controls-v8-steps-template-download-dan-duran/>

CIS CRITICAL SECURITY CONTROLS (CSC CONTROLS) v8



- Al final de cada control técnico de seguridad de cualquier benchmark CIS podemos encontrar qué **CSC Controls** y **Safeguards** están asociados a él
- *¿Qué significa esta tabla?*
 - Que este control técnico de seguridad pertenece al **CSC Control v8 n° 3 "Data Protection"**
 - Mira la tabla anterior
 - Dentro de él, pertenece a la **Safeguard 3.3 "Configure Data Access Control Lists"**

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>3.3 Configure Data Access Control Lists</u> Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	<u>14.6 Protect Information through Access Control Lists</u> Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

- Si hemos usado el CSC Controls v7, esto significa que este control técnico de seguridad pertenece al CSC Control v7 número 14 "Controlled Access Based on Net to Know"
- En su interior, también es aplicable a la Safeguard 14.6 de ese CSC Control 14
- La versión 7 será reemplazada por la v8: no la usaremos

CIS CRITICAL SECURITY CONTROLS (CSC CONTROLS) v8



- Los 18 CSC Controls y sus 153 Safeguards son siempre los mismos
 - No importa el software (jesto es ser "más abstracto"!)
 - Cubren **TODAS** las consideraciones de seguridad de **TODO** el software que tiene un CIS Benchmark
- Pero un CIS Benchmark concreto solo contiene controles técnicos de seguridad que pertenecen a sus salvaguardias aplicables
 - Ej.: ¿Crees que el CIS Benchmark de Chrome tendrá controles de seguridad técnicos asignados a cualquier Safeguard del CSC Control 1 "Inventory and Control of Hardware Assets"?

NUMBER	TITLE/DESCRIPTION	ASSET TYPE	SECURITY FUNCTION	IG1	IG2	IG3
13.1	Centralize Security Event Alerting Centralize security event alerting across enterprise assets for log correlation and analysis. Best practice implementation requires the use of a SIEM, which includes vendor-defined event correlation alerts. A log analytics platform configured with security-relevant correlation alerts also satisfies this Safeguard.	Network	Detect			
13.2	Deploy a Host-Based Intrusion Detection Solution Deploy a host-based intrusion detection solution on enterprise assets, where appropriate and/or supported.	Devices	Detect			
13.3	Deploy a Network Intrusion Detection Solution Deploy a network intrusion detection solution on enterprise assets, where appropriate. Example implementations include the use of a Network Intrusion Detection System (NIDS) or equivalent cloud service provider (CSP) service.	Network	Detect			
13.4	Perform Traffic Filtering Between Network Segments Perform traffic filtering between network segments, where appropriate.	Network	Protect			
13.5	Manage Access Control for Remote Assets Manage access control for assets remotely connecting to enterprise resources. Determine amount of access to enterprise resources based on: up-to-date anti-malware software installed, configuration compliance with the enterprise's secure configuration process, and ensuring the operating system and applications are up-to-date.	Devices	Protect			
13.6	Collect Network Traffic Flow Logs Collect network traffic flow logs and/or network traffic to review and alert upon from network devices.	Network	Detect			
13.7	Deploy a Host-Based Intrusion Prevention Solution Deploy a host-based intrusion prevention solution on enterprise assets, where appropriate and/or supported. Example implementations include use of an Endpoint Detection and Response (EDR) client or host-based IPS agent.	Devices	Protect			
13.8	Deploy a Network Intrusion Prevention Solution Deploy a network intrusion prevention solution, where appropriate. Example implementations include the use of a Network Intrusion Prevention System (NIPS) or equivalent CSP service.	Network	Protect			
13.9	Deploy Port-Level Access Control Deploy port-level access control. Port-level access control utilizes 802.1x, or similar network access control protocols, such as certificates, and may incorporate user and/or device authentication.	Devices	Protect			
13.10	Perform Application Layer Filtering Perform application layer filtering. Example implementations include a filtering proxy, application layer firewall, or gateway.	Network	Protect			
13.11	Tune Security Event Alerting Thresholds Tune security event alerting thresholds monthly, or more frequently.	Network	Detect			

Algunas Safeguards del control CSC 13 " Network Monitoring and Defense ". Fuente: <https://blog.usecure.io/cis-critical-security-controls-v8>

DE CONTROLES TÉCNICOS DE SEGURIDAD A CONTROLES CSC

CIS Benchmark (PDF)
de Ubuntu 22.04



CSC Controls v8
(y sus Safeguards)

<https://www.cisecurity.org/controls/cis-controls-navigator>

Todos los controles de seguridad
técnicos de la Safeguard 3.3



CSC Control 3 – *Data Protection*

- *Safeguard 3.3: Configure Data Access Control Lists*

CIS Control 3 - Data Protection ▾

- ✓ Safeguard 3.1: Establish and Maintain a Data Management Process
- ✓ Safeguard 3.2: Establish and Maintain a Data Inventory
- ✓ Safeguard 3.3: Configure Data Access Control Lists
- ✓ Safeguard 3.4: Enforce Data Retention

Todos los controles de seguridad técnicos
de las Safeguards 4.3 y 4.8



CSC Control 4 – *Secure Configuration of Enterprise Assets and Software*

- *Safeguard 4.3: Configure Automatic Session Locking on Enterprise Assets*
- *Safeguard 4.8: Uninstall or Disable Unnecessary Services on Enterprise Assets and Software*

CIS Control 4 - Secure Configuration of Enterprise Assets and Software ▾

- ✓ Safeguard 4.1: Establish and Maintain a Secure Configuration Process
- ✓ Safeguard 4.2: Establish and Maintain a Secure Configuration Process for Network Infrastructure
- ✓ Safeguard 4.3: Configure Automatic Session Locking on Enterprise Assets
- ✓ Safeguard 4.4: Implement and Manage a Firewall on Servers
- ✓ Safeguard 4.5: Implement and Manage a Firewall on End-User Devices
- ✓ Safeguard 4.6: Securely Manage Enterprise Assets and Software
- ✓ Safeguard 4.7: Manage Default Accounts on Enterprise Assets and Software
- ✓ Safeguard 4.8: Uninstall or Disable Unnecessary Services on Enterprise Assets and Software
- ✓ Safeguard 4.9: Configure Trusted DNS Sources on Enterprise Assets

Todos los controles de seguridad técnicos
las Safeguards 8.2 y 8.9



CSC Control 8 – *Audit Log Management*

- *Safeguard 8.2: Collect Audit Logs*
- *Safeguard 8.9: Centralize Audit Logs*

CIS Control 8 - Audit Log Management ▾

- ✓ Safeguard 8.1: Establish and Maintain an Audit Log Management Process
- ✓ Safeguard 8.2: Collect Audit Logs
- ✓ Safeguard 8.3: Ensure Adequate Audit Log Storage
- ✓ Safeguard 8.4: Standardize Time Synchronization
- ✓ Safeguard 8.5: Collect Detailed Audit Logs
- ✓ Safeguard 8.6: Collect DNS Query Audit Logs
- ✓ Safeguard 8.7: Collect URL Request Audit Logs
- ✓ Safeguard 8.8: Collect Command-Line Audit Logs
- ✓ Safeguard 8.9: Centralize Audit Logs
- ✓ Safeguard 8.10: Retain Audit Logs



Frameworks de seguridad y SGSI

Cumplimiento de normas internacionales



CIS, FRAMEWORKS Y POLÍTICAS DE SEGURIDAD



● ¿Qué Safeguards implementar? ¿Todas? ¿Algunas?

- ¡Depende de nuestros recursos! (dinero y tiempo)
- Podría decidirse utilizando Implementation Groups (IG)
 - <https://www.cisecurity.org/controls/implementation-groups>
- Pero **es un concepto solo del CIS**, y necesitamos algo más internacional
- ¡Un **framework** de seguridad!

● Se usan muchos frameworks de seguridad en todo el mundo, algunos aplicados solo en ciertos sectores

- Todos tienen controles de seguridad de alto nivel (como los CSC Controls/Safeguards)
- ¡Los CIS Benchmarks pueden ayudarnos a **lograr el cumplimiento de muchos de ellos!**
 - Los CSC Controls/Safeguards se pueden mapear a los controles de muchos frameworks
 - <https://www.cisecurity.org/cybersecurity-tools/mapping-compliance/>
- Los frameworks son diferentes... ¡pero no TAN diferentes! 😊

TYPE	SECURITY FUNCTION	IG1	IG2	IG3
work	Detect			
n and analysis. Best practice event correlation alerts. A log analytics is Safeguard.				
ices	Detect			
re appropriate and/or supported.				
work	Detect			
ppropriate. Example implementations nt cloud service provider (CSP) service.				
work	Protect			
ices	Protect			
ces. Determine amount of access to configuration compliance with the m and applications are up-to-date.				
work	Detect			
pon from network devices.				
ices	Protect			
ere appropriate and/or supported. nse (EDR) client or host-based IPS agent.				
work	Protect			
e implementations include the use of a				
ices	Protect			
r similar network access control hentication.				
work	Protect			
ing proxy, application layer				
work	Detect			



- **Frameworks populares usados en todo el mundo**
 - **Payment Card Industry Data Security Standard (PCI DSS)**
 - **NIST Cybersecurity Framework**
 - **Health Insurance Portability and Accountability Act (HIPAA)**
 - Bases de seguridad para proteger los datos de los pacientes en empresas/organizaciones relacionadas con la salud
 - **General Data Protection Regulation 2016/679 (EU) (ASLEPI)**
 - <https://www.cisecurity.org/gdpr/>
 - **International Organization for Standardization (ISO) ISO/IEC 27001 (la que elegimos en esta asignatura)**
 - Son estándares mundiales independientes y validados para garantizar la ciberseguridad
 - Ayuda a las empresas a defenderse contra las amenazas cibernéticas y los riesgos de seguridad

CIS Controls v8 Mappings

Download individual mappings below or visit our [CIS Controls Navigator](#) for all mappings to CIS Controls v8.

- [AICPA Trust Services Criteria \(SOC2\)](#)
- [ASD's Essential Eight](#)
- [Azure Security Benchmark](#)
- [CISA's Cross-Sector CPGs](#)
- [CMMC Cybersecurity Maturity Model Certification v2.0](#)
- [CRI Profile v1.2](#)
- [Criminal Justice Information Services](#)
- [CSA CCM Cloud Security Alliance Cloud Control Matrix](#)
- [Cyber Essentials v2.2](#)
- [FFEIC-CAT](#)
- [GSMA FS.31 Baseline Security Controls](#)
- [HIPAA Health Insurance Portability and Accountability Act of 1996](#)
- [ISACA COBIT 19](#)
- [ISO/IEC 27001:2022](#)
- [ISO/IEC 27002:2022](#)
- [MITRE Enterprise ATT&CK v8.2](#)
- [NCSC Cyber Assessment Framework v3.1](#)
- [NERC-CIP](#)
- [New Zealand Information Security Manual \(NZISM\) v3.5](#)
- [NIST CSF](#)
- [NIST Special Publication 800-53 Rev.5 \(Moderate and Low Baselines\)](#)
- [NIST Special Publication 800-171 Rev.2](#)
- [NYDFS Part 500](#)
- [PCI Payment Card Industry v4.0](#)
- [TSA Security Directive Pipeline 2021-02](#)

Mapeos de los CSC Controls v8 a otros frameworks: <https://www.cisecurity.org/controls/v8>

DE CONTROLES CSC A FRAMEWORKS DE SEGURIDAD



● Estos mapeos de CSC Controls / Safeguards son públicos

- <https://www.cisecurity.org/controls/cis-controls-navigator/>

● De esta manera...

- Los controles técnicos de los Benchmarks CIS mejoran la seguridad del software
- Una vez implementados, se calcula cuántos CSC Controls y Safeguards están cubriendo
- Luego se pueden **mapear** al marco de ciberseguridad que desea implementarse
 - Así el trabajo se puede traducir a cualquiera de esos frameworks
- Así se implementa un SGSI más fácilmente
- Controles técnicos -> controles abstractos -> controles de frameworks particulares -> SGSI
 - ¡De la línea de comandos a la documentación!

Mappings

IG1 IG2 IG3

☐ Australian Signals Directorate's 'Essential Eight' See details	☐ Azure Security Benchmark v3 See details	☐ CISA Cross-Sector Cybersecurity Performance Goals See details
☐ CISA Cybersecurity Performance Goals See details	☐ CMMC v2.0 See details	☐ Criminal Justice Information Services (CJIS) Security Policy See details
☐ CSA Cloud Controls Matrix v4 See details	☐ Cyber Risk Institute (CRI) Profile v1.2 See details	☐ Federal Financial Institutions Examination Council (FFIEC-CAT) See details
☐ GSMA FS.31 Baseline Security Controls v2.0 See details	☐ HIPAA See details	☐ ISACA COBIT 19 See details
☒ ISO/IEC 27001:2022 & 27002:2022 Information Security Controls See details	☐ MITRE Enterprise ATT&CK v8.2 See details	☐ New Zealand Information Security Manual v3.5 See details
☐ NIST CSF See details	☐ NIST SP 800-171 See details	☐ NIST SP 800-53 Revision 5 Low Baseline See details
☐ NIST SP 800-53 Revision 5 Moderate Baseline	☐ North American Electric Reliability Corporation-Critical	☐ NYDFS Part 500 See details

CIS Control 1 - Inventory and Control of Enterprise Assets

☒ **Safeguard 1.1: Establish and Maintain Detailed Enterprise Asset Inventory**

Establish and maintain an accurate, detailed, and up-to-date inventory of all enterprise assets with the potential to store or process data, to include: end-user devices (including portable and mobile), network devices, non-computing/IoT devices, and servers. Ensure the inventory records the network address (if static), hardware address, machine name, enterprise asset owner, department for each asset, and whether the asset has been approved to connect to the network. For mobile end-user devices, MDM type tools can support this process, where appropriate. This inventory includes assets connected to the infrastructure physically, virtually, remotely, and those within cloud environments. Additionally, it includes assets that are regularly connected to the enterprise's network infrastructure, even if they are not under control of the enterprise. Review and update the inventory of all enterprise assets bi-annually, or more frequently.

IG1 IG2 IG3

MAPPINGS

ISO/IEC 27001:2022 & 27002:2022 Information Security Controls

5.9	Inventory of information and other associated assets - 1
8.8	Management of technical vulnerabilities - 1

**¿Cumples con la Safeguard 1.1?
Ahora también tienes parte del
trabajo de cumplimiento realizado
con los controles 5.9 y 8.8 del
framework ISO 27001:2022**

SISTEMA DE GESTIÓN DE SEGURIDAD DE LA INFORMACIÓN (SGSI)



- La gestión de la seguridad debe hacerse
 - Con un proceso **sistemático, documentado y conocido**
 - **Aceptado en toda la empresa** (sin exclusiones, sin importar la experiencia, la posición...)
- El proceso de gestión se llama **Sistema de Gestión de la Seguridad de la Información (SGSI)**
 - Information Security Management System, ISMS
- Su objetivo es

*"Garantizar que los **riesgos** para la seguridad de la información son **conocidos, asumidos, administrados y minimizados** por la empresa, que utiliza un procedimiento documentado, sistemático, estructurado, repetible y eficiente, que también debe adaptarse para responder a los **cambios de los riesgos, entorno y tecnología**"*
- La garantía total **NUNCA** es posible
 - Pero asegura que la empresa está preparada para asumir la **pérdida de CIA** de la información



Competencias que debe cumplir cualquier estándar para implementar un SGSI

ELEMENTOS DEL SGSI



- La implementación de un SGSI requiere...
 - Una **política de seguridad, estructura organizativa, procedimientos, procesos y recursos**
- Implementar uno significa que una empresa
 - **Estudió** sus riesgos potenciales y **evaluó** su nivel de riesgo
 - **Implementó** controles de seguridad tecnológicos / organizacionales
 - **Para reducir los riesgos** que están más allá de un nivel aceptable
 - **Documentó** políticas y procedimientos relacionados
 - Cumpliendo con el **marco legal (ASLEPI)**
 - Implementó un proceso continuo de **revisión y mejora** de todo el sistema
 - Esto significa **ahorro de costes y mejora de la competitividad;**
¿Por qué?
- Existen normas de implementación (Ej.: ISO 27001)
 - Hay muchos más estándares (país, contexto...)

 COBIT Control Objectives for Information and Related Technologies It's a framework developed by ISACA that focuses on governance and management of information & technology. It provides a set of control objectives to help organizations achieve their business objectives through effective management and governance of their IT assets. FOCUS : Business and IT Governance. Emphasizes information governance and process improvement PURPOSE : Aligning business goals with IT functions and ensuring effective risk management APPLICABILITY : Broad spectrum, suitable for all organization sizes KEY FUNCTIONS : Control objectives, Risk management, Information governance, Process improvement, IT alignment	 ISO 27001 International Organization for Standardization It's a global standard for Information Security Management Systems (ISMS). It outlines the criteria for establishing, implementing, maintaining, and continually improving an information security management system. The standard includes a set of controls that organizations can implement to manage information security risks. FOCUS : Information security systems. Systematic approach to managing sensitive company information PURPOSE : Establishing, implementing, maintaining, and improving an information security management system APPLICABILITY : Globally recognized, suitable for any organization KEY FUNCTIONS : Risk assessment, Security policy, Access control, Cryptography, Incident response, Continual improvement	 NIST National Institute of Standards and Technology The NIST Cybersecurity Framework provides a set of guidelines and best practices for organizations to manage and improve their ability to prevent, detect, respond to, and recover from cybersecurity events. It is widely used in the United States and has been adopted globally. FOCUS : Cybersecurity and Risk Management. Emphasizes continuous monitoring and risk assessment PURPOSE : Providing a flexible and comprehensive approach to managing and mitigating cybersecurity risk APPLICABILITY : Widely used in the United States, adopted globally KEY FUNCTIONS : Identify, Protect, Detect, Respond, Recover, Continuous monitoring
--	--	---

● **Marco de gestión de la seguridad de la información para cualquier organización**

- Contiene los requisitos para establecer, implementar, operar, monitorizar, mantener y mejorar un SGSI
- La 27001 es un **estándar de gestión** que recopila
 - Los **componentes** del sistema
 - Los **documentos mínimos** que forman parte de él
 - Los **registros** (logs) de información,
 - Los **controles de seguridad** a implementar (**93 en total**, listados en el **Anexo A de la norma**)
 - Contiene la **visión general básica** de los controles de seguridad necesarios para implementar un SGSI
 - ¡Equivalentes a los Controles CSC que hemos visto!
 - Las **medidas de seguridad adaptadas** a las necesidades de cada organización

● **Nos centraremos en su Anexo A (controles de seguridad)**

● **En España, AENOR es la principal agencia de certificación**

- Asociación Española de NORmalización y certificación <http://www.aenor.es/aenor/inicio/home/home.asp>

ANEXO A DE LA NORMA 27001:2022



SSI

● Divide sus 93 controles de seguridad en 4 capítulos

- Controles **organizativos** (37)
- Controles de **personas** (8)
- Controles **físicos** (14)
- Controles **tecnológicos** (34)

● Equivalente a los 18 controles CSC y 153 salvaguardas

● Más información

- <https://normaISO27001.es/>
- <https://www.escuelaeuropeaexcelencia.com/2022/11/publicada-la-nueva-iso-270012022-novedades-del-estandar-de-seguridad-de-la-informacion/>
- <https://blog.innevo.com/iso27001-2022>

5. Organizational controls	6. People controls	8. Technological controls
5.1. Policies for information security 5.2. Information security roles and responsibilities 5.3. Segregation of duties 5.4. Management responsibilities 5.5. Contact with authorities 5.6. Contact with special interest groups 5.7. Threat intelligence 5.8. Information security in project management 5.9. Inventory of information and other associated assets 5.10. Acceptable use of information and other associated assets 5.11. Return of assets 5.12. Classification of information 5.13. Labelling of information 5.14. Information transfer 5.15. Access control 5.16. Identity management 5.17. Authentication information 5.18. Access rights 5.19. Information security in supplier relationships 5.20. Addressing information security within supplier agreements 5.21. Managing information security in the ICT supply chain 5.22. Monitoring, review and change management of supplier services 5.23. Information security for use of cloud services 5.24. Information security incident management planning and preparation 5.25. Assessment and decision on information security events 5.26. Response to information security incidents 5.27. Learning from information security incidents 5.28. Collection of evidence 5.29. Information security during disruption 5.30. ICT readiness for business continuity 5.31. Legal, statutory, regulatory and contractual requirements 5.32. Intellectual property rights 5.33. Protection of records 5.34. Privacy and protection of PII 5.35. Independent review of information security 5.36. Compliance with policies, rules and standards for information security 5.37. Documented operating procedures	6.1. Screening 6.2. Terms and conditions of employment 6.3. Information security awareness, education and training 6.4. Disciplinary process 6.5. Responsibilities after termination or change of employment 6.6. Confidentiality or non-disclosure agreements 6.7. Remote working 6.8. Information security event reporting 7. Physical controls 7.1. Physical security perimeter 7.2. Physical entry 7.3. Securing offices, rooms and facilities 7.4. Physical security monitoring 7.5. Protecting against physical and environmental threats 7.6. Working in secure areas 7.7. Clear desk and clear screen 7.8. Equipment siting and protection 7.9. Security of assets off-premises 7.10. Storage media 7.11. Supporting utilities 7.12. Cabling security 7.13. Equipment maintenance 7.14. Secure disposal or re-use of equipment	8.1. User endpoint devices 8.2. Privileged access rights 8.3. Information access restriction 8.4. Access to source code 8.5. Secure authentication 8.6. Capacity management 8.7. Protection against malware 8.8. Management of technical vulnerabilities 8.9. Configuration management 8.10. Information deletion 8.11. Data masking 8.12. Data leakage prevention 8.13. Information backup 8.14. Redundancy of information processing facilities 8.15. Logging 8.16. Monitoring activities 8.17. Clock synchronization 8.18. Use of privileged utility programs 8.19. Installation of software on operational systems 8.20. Network security 8.21. Security of network services 8.22. Segregation of networks 8.23. Web filtering 8.24. Use of cryptography 8.25. Secure development life cycle 8.26. Application security requirements 8.27. Secure system architecture and engineering principles 8.28. Secure coding 8.29. Security testing in development and acceptance 8.30. Outsourced development 8.31. Separation of development, test and production environments 8.32. Change management 8.33. Test information 8.34. Protection of information systems during audit testing

*New control, 2022

by Andrey Prozorov, CISM, CIPP/E, CDPSE, LA 27001 - www.patreon.com/AndreyProzorov

Control: measure that maintains and/or modifies risk

Esta norma divide la ciberseguridad en menos grupos y controles de seguridad que el CSC del CIS. Fuente: <https://twitter.com/hackinarticles/status/1714682070960615761>

¿QUÉ ES LA NORMA ISO 27002:2022?

● Complemento de la norma ISO 27001

- No es una norma de gestión, sino un **conjunto de directrices y buenas prácticas**
- Explican **cómo implementar** los controles de seguridad contenidos en el Anexo A de la ISO 27001

● No ser un estándar de gestión implica

- Explica todos los controles del Anexo A **sin importar si una organización los necesita o no**
- Es **mucho más detallada y precisa**
 - Y por eso ayuda a comprender si una organización debe aplicar o no ciertos controles de seguridad
- Permite no depender de especificaciones de 3ºs de cómo implementar controles
 - ¡Pero podemos **usar los controles CSC** (o cualquiera similar) para implementar el Anexo A de ISO 27001!



Obviamente, la ISO 27002:2022 usa la misma división de controles de 4 capítulos que la ISO 27001:2022 que complementa. Fuente:

https://twitter.com/Marce_I_P/status/1681992650751111169

DE LOS CONTROLES CIS CSC A LOS CONTROLES ISO 27001: ANEXO A

CIS Benchmark (PDF)
de Ubuntu 22.04



CSC Controls v8
(y sus Safeguards)

Mapean a*



Controles de seguridad de
ISO 27001:2022

Todos los controles técnicos de
seguridad de la **Safeguard 3.3**



CSC Control 3 – *Data Protection*

- *Safeguard 3.3: Configure Data Access Control Lists*

5.10 Acceptable use of
information and other associated
assets
5.15 Access control
8.3 Information access restriction
8.4 Access to source code



Todos los controles técnicos de seguridad
de las **Safeguards 4.3 y 4.8**



CSC Control 4 – *Secure Configuration of Enterprise Assets and Software*

- *Safeguard 4.3: Configure Automatic Session Locking on Enterprise Assets*
- *Safeguard 4.8: Uninstall or Disable Unnecessary Services on Enterprise Assets and Software*

8.5 Secure authentication
8.9 Configuration management



Todos los controles técnicos de seguridad
las **Safeguards 8.2 y 8.9**



CSC Control 8 – *Audit Log Management*

- *Safeguard 8.2: Collect Audit Logs*
- *Safeguard 8.9: Centralize Audit Logs*

8.15 Logging
8.20 Networks security



No tiene mapeo (pero se puede
añadir al SoA si la organización lo
estima oportuno)

¿PUEDES AYUDARME A ENTENDER EL PROPÓSITO DE LOS CONTROLES?



ISO 27001:2022 Controls Made Easy - Part 1

● “Ministry of Security” publicó una serie de documentos llamados “ISO 27001 controls made easy” (4 partes)

- Explican cada control asumiendo que estás en una escuela, dándote ejemplos concretos de su propósito

● Muy útil para entender los objetivos de cada control

• 5. Organizational controls

- https://www.linkedin.com/posts/ministry-of-security_iso-27001-2022-made-easy-part-1-activity-7270625600153804801-JeVs/

• 6. People controls

- https://www.linkedin.com/posts/ministry-of-security_iso-27001-2022-made-easy-part-2-activity-7275706503909580800-vywS/

• 7. Physical controls

- https://www.linkedin.com/posts/ministry-of-security_iso-27001-2022-made-easy-part-3-activity-7278243208759820288-3mTI/

• 8. Tecnológico controls No disponible (puede usar los CSC 😊)

- https://www.linkedin.com/posts/ministry-of-security_iso-270012022-audit-checklist-activity-7143832341344305153-A3ms/

Control Number	Control Name	Real Life Example	Implementation Guidance
5.1	Policies for information security	Think about a school's rule system. They have a main handbook with core rules (like student conduct, safety, or attendance policies) that everyone must follow. Then, they have specific policy sets for different activities - for lab safety rules, library policies, computer usage guidelines, and exam regulations. Just as these rules are reviewed and updated each year based on new needs (like adding online class rules during pandemic), and communicated to all students, teachers, and parents through orientations and circulars. Information Security Connection: Organizations need a similar structured approach to security policies. Like schools having a main handbook and specific rules, companies need a main security policy supported by detailed topic-specific policies (like password rules, data handling, network security). These policies must be approved by management, communicated clearly to all employees, and updated regularly to address new threats or business changes.	• Create Information Security Policy aligned with business objectives and requirements • Develop topic-specific policies for key areas (access control, password management, etc.) • Ensure policies include clear objectives, scope, roles and responsibilities • Establish policy management processes including regular reviews • Document and maintain policy acknowledgments and changes • Communicate policies effectively using clear language and awareness sessions
5.2	Information security roles and responsibilities	In a school, each role has specific security responsibilities. The Principal oversees overall security, Department Heads protect teaching materials, IT Teacher manages computer security, and Administrative staff secures student records. Like how a School Counsellor knows they must keep student discussions confidential, each person understands their role in protecting school information. Information Security Connection: Just as schools clearly define who's	• Create security organization structure (CISO, Security Managers, Operations teams) • Define responsibilities for each role (decisions, access rights, reporting lines) • Document and communicate through job descriptions and policies • Provide role-specific training and verify

¿Tienes curiosidad por saber el propósito de estos controles? ¡Lee esta serie y todo claro!! 😊

ETAPAS DE IMPLEMENTACIÓN DEL SGSI (CICLO DE DEMING)

● La norma ISO 27001 proporciona un marco para implementar un SGSI en cuatro fases

- **PLAN (Planificar)**: Establecer el SGSI
 - Solo revisaremos algunas actividades de PLAN
 - ¿Quieres saber más? “¡Enrólate en la “**Blas de Lezo**”! 😊
- **DO (Hacer)**: Implementarlo y usarlo
- **CHECK (Verificar)**: Supervisar, revisar y verificarlo
- **ACT (Actuar)**: Mantenimiento y mejora del SGSI

Fuente: http://www.iso27000.es/sgsi_implantar.html

Basado en la filosofía “Kaizen” de mejora continua:
<https://es.wikipedia.org/wiki/Kaizen>



PLAN: DEFINIR LA POLÍTICA DE SEGURIDAD DE LA INFORMACIÓN



● Directrices y objetivos generales de la empresa relacionados con la seguridad

- Escritos formalmente y aprobados por la dirección de esta
- Es la "constitución" de su organización (¡como la española!)

● Incluye

- **Objetivos y alcance** general de seguridad
- **Apoyo expreso de la dirección** (CEO / gestión)
- Explicación de los **valores de seguridad** de la organización
- **Definición de las responsabilidades** generales y específicas en materia de gestión de la seguridad de la información
- **Referencias a documentos** que puedan respaldar la política

● No debería ser un documento grande

INFORMATION SECURITY POLICY INCLUSIONS



Access control



Identification and Authentication
(including multi-factor authentication and passwords)



Data classification



Encryption



Remote access



Acceptable use



Patching



Malicious code protections



Physical security



Backups



Server security
(e.g. hardening)



Employee on/offboarding



Change management

PLAN: EJEMPLO DE POLÍTICA DE SEGURIDAD DE LA INFORMACIÓN



Objetivo:

Definir las pautas de propósito general para asegurar una adecuada protección de la información del DAPRE.

Brindar apoyo y orientación a la dirección con respecto a la seguridad de la información, de acuerdo con los requisitos del negocio y los reglamentos y las leyes pertinentes.

Aplicabilidad:

Estas son políticas que aplican a la Alta Dirección, Ministros, Consejeros, Consejeros Presidenciales, Directores, Secretarios, Jefes de Oficina, Jefes de Área, funcionarios, contratistas, y en general a todos los usuarios de la información que cumplan con los propósitos generales del DAPRE.

Directrices:

- Se debe verificar que se definan, implementen, revisen y actualicen las políticas de seguridad de la información.
- Diseñar, programar y realizar los programas de auditoría del sistema de gestión de seguridad de la Información, los cuales estarán a cargo de control interno.

- Todo aplicativo informático o software debe ser comprado o aprobado por el Área de Información y Sistemas en concordancia con la política de adquisición de bienes de la entidad de acuerdo con lo definido en el proceso **C-BS-07 Adquisición de Bienes y Servicios**.
- El DAPRE debe contar con un firewall o dispositivo de seguridad perimetral para la conexión a Internet o cuando sea inevitable para la conexión a otras redes en outsourcing o de terceros.
- La conexión remota a la red de área local del DAPRE debe realizarse a través de una conexión VPN segura suministrada por la entidad, la cual debe ser aprobada, registrada y auditada, a excepción de los casos que autorice el Área de Información y Sistemas.
- Los jefes de área o dependencia deben asegurarse de que todos los procedimientos de seguridad de la información dentro de su área de responsabilidad se realizan correctamente para lograr el cumplimiento de las políticas y estándares de seguridad de la información del DAPRE.

PLAN: DEFINIR POLÍTICAS DE SEGURIDAD ESPECÍFICAS



● Además, ISO 27001 necesita definir políticas más específicas adaptadas a la organización (si son aplicables)

- Se trata de **políticas concretas** aplicables a muchas situaciones de trabajo cotidianas
- Controles de seguridad detallados (pero aún abstractos) **para áreas concretas**
- Si la política de seguridad de la información es su "constitución", estas son las **leyes** que desarrollan cada parte de esta

● Debes documentar cómo hace **TODO** en cuanto a seguridad

- ¡Se pueden encontrar ejemplos de plantillas de políticas en Internet para empezar!

● Pero primero, necesitas **CONOCERTE A TI MISMO**

- Significa **crear un inventario**: Todos tus activos, software, personas, oficinas...
- Y conocer y evaluar **sus riesgos de seguridad**

- 
- Data Protection Policy
 - Data Retention Policy
 - Access Control Policy
 - Asset Management Policy
 - Risk Management Policy
 - Information Classification and Handling Policy
 - Information Security Awareness and Training Policy
 - Acceptable Use Policy
 - Clear Desk and Clear Screen Policy
 - Remote Working Policy
 - Business Continuity Policy
 - Backup Policy
 - Malware and Antivirus Policy
 - Change Management Policy
 - Third Party Supplier Security Policy
 - Continual Improvement Policy
 - Logging and Monitoring Policy
 - Network Security Management Policy
 - Information Transfer Policy
 - Secure Development Policy
 - Physical and Environmental Security Policy
 - Cryptographic Key Management Policy
 - Cryptographic Control and Encryption Policy
 - Document and Record Policy

PLAN: DEFINIR ACTIVOS

● Los activos son cualquier cosa lo suficientemente valiosa como para ser protegida en una organización

- Información
- Edificios
- Sistemas y redes informáticas
- Aplicaciones
- Bases de datos
- Medios de almacenamiento
- ... (ver imagen)

Activos ISO 27002:2022.

Fuente

[:https://twitter.com/Marce_LP/](https://twitter.com/Marce_LP/)

● La definición de activos debe incluir

- Un **inventario**: Descripción, localización, propietario...
- **Dependencias** entre activos
- **Calificación** de los activos, dependiendo de su relevancia y del impacto potencial que puedan tener si se produce algún incidente sobre ellos

En el contexto de "la seguridad de la información" se pueden distinguir dos clases de activos



ISO/IEC
27002:2022

Es esencial que una organización defina sus requerimientos de seguridad de la información. Hay tres fuentes principales de requerimientos:

- a) La evaluación de riesgos de la organización, considerando al negocio en su conjunto, estrategia y objetivos.
- b) Los requerimientos legales, estatutarios, regulatorios y contractuales que la organización y sus partes interesadas tienen que cumplir en su entorno sociocultural.
- c) El conjunto de principios, objetivos, y requerimientos del negocio para todas las etapas del ciclo de vida de la información que la organización desarrolla para poder realizar sus operaciones.

- Fuente:** <https://www.metrici.com/metrici/forum/threads/Thread4>

ISMS.online

[Home](#)
[You](#)
[Work](#)

David

[Tracks](#)
[Information Asset Inventory \(ISO 27001\)](#)

Information Asset Inventory (ISO 27001)

[Linked work](#)
[Team](#)
[Settings](#)
[Tour](#)

Showing: 16 of 16
Summary value £0.00
(from total £0.00)

[View Archive](#)
[View Updates feed](#)
[View Stats](#)
[New Item](#)

Assigned to:
All Team Members
Category:
Selected
Status:
All Statuses
View:
Columns
List

Name	Status	Primary Location	Legal Owner	Classification	Owner/Lead	Type	Assigned To	Due
2 - Laptops: company provided	Live	Company Office On Person Teleworker (Home)	Company	Commercial in Confidence	CTO	Processing Devices	David Kelly	07/01/19 11:00
7 - Brand	Live	Everywhere	Company	Commercial in Confidence	CMO (marketing)	Sales & Marketing IPR	David Kelly	07/01/19 12:00
8 - Company financial data	Live	Company Office	Company	Commercial in Confidence	FD	Financial information	Karen Arnold	07/01/19 14:00
13 - Product X code base	Live	Third Party Datacentre	Company	Infrastructure Critical	CEO	Products & Services Infrastructure IPR	Gill Smith	07/01/19 14:00
9 - Product marketing materials (published)	Live	Everywhere	Company	Public	CMO (marketing)	Products & Services Sales & Marketing IPR		07/01/19 18:00
1 - Staff personal data	Resolved	Company Office	Company	Commercial in Confidence	HR	Personal Data		
3 - Laptops: Infrastructure Critical focused	To-do							
4 - Laptops: BYOD (employee)	To-do							
5 - Mobile Phones: company provided	To-do							
6 - Mobile Phones: BYOD (employee)	To-do							

☐ Third Party Datacentre
☐ Other Location

☐ Legal Owner

☐ Company
☐ Employee (inc.BYOD)
☐ Supplier
☐ Customer
☐ Other

☐ Classification

☐ Infrastructure Critical
☐ Commercial in Confidence
☐ Public
☐ Unknown

☐ Owner/Lead

☐ CEO
☐ DPO

☐ Uncategorized

[Clear all options](#)
[Apply filter](#)

PLAN: ANÁLISIS DEL RIESGO

- **Probabilidad de que una amenaza explote una vulnerabilidad y cause daños (o pérdida total) de un activo**
 - Suelen expresarse combinando la probabilidad de un evento y sus consecuencias
- **Existen varias metodologías de evaluación y análisis de riesgos**
 - La norma ISO 27001 no obliga a su uso (MAGERIT es común en la administración española)
- **Verás esto en DPPI (4to año)**

Risk assessment matrix

		Severity →				
		Negligible	Minor	Moderate	Significant	Severe
Likelihood ↑	Very Likely	Low Med	Medium	Med Hi	High	High
	Likely	Low	Low Med	Medium	Med Hi	High
	Possible	Low	Low Med	Medium	Med Hi	Med Hi
	Unlikely	Low	Low Med	Low Med	Medium	Med Hi
	Very Unlikely	Low	Low	Low Med	Medium	Medium

Risk Matrix Example

Likelihood X Severity = Risk Level

Matriz de evaluación de riesgos de ejemplo. Fuente:

<https://www.riskpal.com/risk-assessment-matrices/>

PLAN: ANÁLISIS DEL RIESGO

- Para calcular **niveles de riesgo de activos identificados** tenemos que
 - Identificar **amenazas** a los activos cubiertos por el SGSI
 - Identificar **vulnerabilidades** que podrían ser explotadas por las amenazas
 - Identificar y evaluar el **impacto** (coste) de un activo que falle
 - Evaluar la **probabilidad de fallo**
 - Teniendo en cuenta los 3 elementos anteriores
 - Calcular los **niveles de riesgo** utilizando un método objetivo
 - Determinar si el riesgo calculado es **aceptable** o si se requiere alguna acción

AMENAZA	VULNERABILIDAD
Ataque por una organización o individuo cibercriminal	Un problema de configuración permite la conexión a servicios privados evadiendo reglas del firewall
	XSS por falta de validación adecuada que lleva a ejecución de scripts
	XST causado por un error de filtrado y usar el verbo HTTP TRACE
Sobrecalentamiento de equipo	No hay monitorización de temperatura
Datos filtrados en un servidor	Instalación Tomcat por defecto
Incendio	No hay extintores en el edificio

Activo	Amenaza	Vulnerabilidad	Impacto			Probabilidad	Riesgo	Clasificación del riesgo
			Confidencialidad	Integridad	Disponibilidad			
Portátil	Robo	Portabilidad	2	3	1	1	3	
Servidor ficheros	Malware	Falta de actualizaciones	3	3	3	1	4	
Contrato cliente	Robo	No hay caja fuerte	4	4	1	2	5	
Datos cliente	Filtrado	No se autentica el acceso	5	4	3	2	6	

● Identificar y evaluar alternativas para tratar los riesgos para que podamos...

- **Eliminar** el riesgo (Ej.: Eliminar un servidor obsoleto)
- **Mitigar** el riesgo (Ej.: Aplicar controles técnicos de seguridad adecuados)
- **Transferir la gestión del riesgo** a un agente externo
 - Ej.: Subcontratar el servicio de mantenimiento del servidor
- **Asumir** el riesgo (actualmente no puedes lidiar con él)



● Finalmente, se debe analizar el riesgo residual

- Nivel de riesgo existente después de que se hayan implementado todos los tratamientos de riesgo

● La implementación de los controles de seguridad ISO 27001 depende de los resultados del análisis de riesgos de la organización

- La norma solo requiere que la organización implemente **aquellos que realmente se necesiten**
- Según los riesgos identificados, su **impacto** y su **probabilidad** de fallo

PLAN: DEFINIR CONTROLES Y PROCEDIMIENTOS



● Control

- Medidas, acciones y documentos que permitan auditar y cubrir un riesgo

● Procedimiento

- Instrucciones de implementación de tareas / procesos de un control
- Establece los pasos a seguir para implementar las tareas de forma concisa

● Declaración de aplicabilidad / Statement Of Applicability (SOA) con

- Los **objetivos** de control
- Los que **se han elegido** del estándar
- **Por qué** se han elegido esos controles
- Las **medidas de seguridad** adoptadas

Antes de la auditoría de certificación, una organización debe haber producido una Declaración de Aplicabilidad (SOA).

El requisito se describe en la ISO 27001. La SOA debe contener cada una de las categorías y controles enumerados. Una vez hecho esto, cada control debe ser seleccionado y justificado o excluido con una justificación similar. Todos los documentos SoA deben poder

demostrar que se ha tenido en cuenta cada control. Esto significa que un SoA debe contener todas las entradas descritas, enumerando simplemente los controles seleccionados que no cumplan con el requisito.

Este ejemplo muestra cómo se podría presentar una diferencia entre un control seleccionado y excluido dentro de un SoA:

<Company Name>: Statement of Applicability ISO27001:2022 Annex A/ ISO27001:2022 Controls					
ISO27001 Controls	Title	Current controls	Control Applicable (Y/N)	Remarks (with justification for exclusion)	Remarks (overview of implementation)
5	Organizational controls				
5.1	Policies for information security	Information security policy and topic-specific policies shall be defined, approved by management, published, communicated to and acknowledged by relevant personnel and relevant interested parties, and reviewed at planned intervals and if significant changes occur.	"Yes"		
5.2	Information security roles and responsibilities	Information security roles and responsibilities shall be defined and allocated according to the organization needs.	Yes		
5.3	Segregation of duties	Conflicting duties and conflicting areas of responsibility shall be segregated.	Yes		
5.4	Management responsibilities	Management shall require all personnel to apply information security in accordance with the established information security policy, topic-specific policies and procedures of the organization.	Yes		

Un SOA de ejemplo disponible gratuitamente gracias al "Ministry of Security". Fuente: https://www.linkedin.com/posts/ministry-of-security_iso-27001-soa-activity-7152132218889375744-E6lo/

TEMA 3

DEFENDIENDO ENDPOINTS



Departamento de Informática
Universidad de Oviedo



Universidad de Oviedo